

Warsaw, January 17, 2025

Decision

DKN.5131.4.2024

Pursuant to Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572) in connection with Articles 7, 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57(1)(a) and (h), Article 58(2)(i), Article 83(1) – (3), Article 83(4)(a) in connection with Article 24(1), Article 25(1), and Article 32(1) and (2), as well as Article 83(5)(a) and (b) in connection with Article 5(1)(a) and (f), Article 5(2), Article 6(1), Article 9(1), Article 13(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by X. based in K. (K., (...)), President of the Personal Data Protection Office,

1) stating that X. based in K. (K., ul. (...)) violated the provisions:

a) Article 6(1) and Article 9(1) of Regulation 2016/679, consisting of unlawful processing of personal data, including data of a special category through the use of video surveillance in two hospital rooms of the Department (...),

b) Article 13(1) and (2) of Regulation 2016/679, consisting of failure to fulfill the information obligation towards individuals whose personal data were subject to processing due to the introduced video surveillance in two hospital rooms of the Department (...),

which resulted in a violation of Article 5(1)(a) of Regulation 2016/679 (principles of lawfulness, fairness, and transparency) and Article 5(2) of Regulation 2016/679 (principle of accountability), imposes on X. based in K. (K., ul. (...)) an administrative fine in the amount of 687,534.75 PLN (in words: six hundred eighty-seven thousand five hundred thirty-four zlotys and 75/100),

2) stating that X. based in K. violated the provisions: Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679, consisting of failure to apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing using external data carriers, in order to protect the personal data stored there, including protection against accidental loss, destruction, or damage and disclosure to unauthorized persons,

which resulted in a violation of Article 5(1)(f) of Regulation 2016/679 (principles of integrity and confidentiality) and Article 5(2) of Regulation 2016/679 (principle of accountability), imposes on X. based in K. (K., ul. (...)) for the violation of Article 5(1)(f), Article 5(2), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679 an administrative fine in the amount of 458,356.50 PLN (in words: four hundred fifty-eight thousand three hundred fifty-six zlotys and 50/100).

Justification

X. based in K. (K., ul. (...)), hereinafter also referred to as the Administrator, Facility, or Medical Center, is an entity whose primary business activity is focused on providing medical services and healthcare, particularly in the area of (...). It should also be emphasized that the Facility is part of (...), which manages a network of specialized neonatal and obstetric-gynecological hospitals located in (...) Poland (voivodeship (...)), as well as medical centers offering access to professional and comprehensive medical care.

On July 26, 2023, the Medical Center reported a personal data breach involving the loss or theft of memory cards from 2 video surveillance devices that recorded images in 2 rooms of the Department (...). According to the Administrator's declaration indicated in the supplement to the report of the personal data breach, in connection with the occurrence of the incident, he submitted a notification of suspicion of a crime to the Prosecutor's Office (...).

At the same time, on August 3, 2023, an article was published on the website (...) regarding the practices of the Medical Center in relation to the surveillance system used by this entity. The content of

the aforementioned article indicates that journalists from the service, based on information provided by an employee of the aforementioned facility, established that quote: "(...) in the department (...), where I work, the management installed hidden cameras in the router and in the clocks. They had a microphone, which is prohibited. We were not informed in any way about their installation."

Furthermore, quote: "Our private conversations were recorded on the cameras, as well as certainly the images of patients - newborns and premature infants, of which their parents are unaware. (...) the devices 'were configured not to record sound' (according to the informant, they recorded both video and sound)."

The President of the Personal Data Protection Office (hereinafter referred to as the "President of UODO" or "supervisory authority"), in connection with the reported personal data breach...

and the aforementioned press information conducted an explanatory procedure, and then on February 28, 2024, initiated ex officio administrative proceedings regarding the possibility of a violation by X. based in K., as the data administrator, of the obligations arising from Article 5(1)(a) and (f), Article 5(2), Article 6(1), Article 9(1), Article 13(1) and (2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679, in connection with the introduction of video surveillance in 2 rooms of the Department (...) without legal basis and the loss or theft of memory cards on which recordings from the aforementioned video surveillance were stored (case reference DKN.5131.4.2024(...)). The President of UODO, as a result of the conducted explanatory procedure and administrative proceedings, established the following factual state.

I. Video Surveillance in the Department (...). The President of UODO addressed the Administrator in letters dated August 7, 2023, January 31, and February 28, 2024, requesting explanations regarding the implementation of video surveillance in 2 rooms of the Department (...).

From the explanations provided by the Facility in correspondence dated August 17, 2023, February 12, March 11, and August 30, 2024, it follows that:

1) The Facility is subject to video surveillance (without audio recording) covering the area of the building located at ul. (...) in K. (publicly accessible areas and key rooms, including the rooms of the Department (...), in accordance with applicable regulations) and the area around this building,
2) The Administrator indicated the following as the legal basis authorizing him to collect personal data as a result of the introduced temporary video surveillance in the aforementioned rooms of the Department (...):

- Article 23a(1)(2) of the Act of April 15, 2011 on medical activity (Journal of Laws of 2024, item 799) in connection with § 29 of the Regulation of the Minister of Health of March 26, 2019, on detailed requirements that should be met by the premises and equipment of entities performing medical activities (Journal of Laws of 2022, item 402),

- Article 6(1)(f) of Regulation 2016/679 due to a legitimate interest,

- Article 222 of the Act of June 26, 1974, Labor Code (Journal of Laws of 2023, item 1465, as amended) for the purpose of ensuring the safety of employees and protecting property, as well as maintaining the confidentiality of information whose disclosure could expose the employer to harm,

3) Video surveillance in the rooms of the Department (...) was conducted from July 1 to July 23, 2023, and for the realization of the aforementioned actions, the Administrator used clocks with image recording functionality (i.e., a camera mounted in the clock allowing for image recording),

4) The motivation and purpose of implementing video surveillance were concern for the health and safety of newborns, due to the increased number of symptoms of gastrointestinal infections,

5) Personal data obtained through the applied video surveillance cited (...) "were to be stored for no longer than 30 days from the date of recording",

6) The Administrator, in a letter dated February 12, 2024 (date of dispatch: February 13, 2024, date of receipt: February 19, 2024), indicated that before implementing the temporary monitoring (i.e., 2 additional monitoring devices installed in 2 rooms of the Department (...)), an analysis confirming the necessity of introducing the aforementioned solution was not conducted. Furthermore, he emphasized that in the period preceding the application of additional monitoring devices, the Facility took actions aimed at eliminating the occurrence of infections in newborns by: increased cleaning of premises,

fumigation, replacement of sanitary and hygienic devices, increased sanitary regime, conducting training for parents of newborns regarding handwashing and hygiene procedures. The Administrator also informed that cited (...) "Changes to the Regulations (...) concerning video surveillance were introduced by a resolution of the Management Board (...).

7) The Administrator, in a letter dated March 11, 2024, provided the supervisory authority with evidence confirming the implementation (before the introduction of additional video surveillance) of security measures aimed at detecting irregular and unintended behaviors causing infections in newborns in the Department (...) in the form of letters from the Team (...) dated March 21, May 9, and June 7, 2023, analysis (...), and report (...).

8) The Facility indicated that it fulfilled the information obligation towards individuals present on the premises of the medical entity through cited (...) "stickers located on the Hospital building in places where monitoring is applied, containing the aforementioned information and redirecting to the content of the information clause regarding the use of video surveillance, via a QR code redirecting to the website with the relevant clause",

9) Regarding the employees of this medical facility, the Administrator noted that each newly hired person is informed about the applied video surveillance,

10) The employees of the Administrator were informed (information sent via email) about the resolution adopted on June 16, 2021, by the management of X. regarding the introduction of changes to the Regulations (...) concerning the introduction of video surveillance on the premises of the workplace from July 1, 2021,

11) The Administrator attached to the letter dated August 17, 2023, sample photos with stickers informing about the use of video surveillance on its premises, the content of the information clause regarding the use of video surveillance in the hospital, a printout of the email informing all employees about the introduction of changes to the Regulations (...), and the content of the resolution amending the Regulations (...) along with the content of the information clause regarding monitoring on the premises of the workplace.

12) The Administrator, in a letter dated February 12, 2024 (date

****Date of issuance:**** February 13, 2024, date of receipt: February 19, 2024) indicated that access to the full content of the information clause regarding the video surveillance used in the facility is possible (in addition to the QR code) at the reception (the possibility of obtaining the clause in printed form). Furthermore, the full content of this information clause is available on the website of the Medical Center.

13) The Medical Center, in a letter dated October 24, 2023, indicated that according to point 4 of the information clause, video surveillance covers key rooms, which in the analyzed case are the rooms of the Department (...). It should also be emphasized that the analyzed information clause does not include a definition clarifying and explaining the term "key rooms."

14) The Administrator, in a letter dated March 11, 2024 (date of receipt: March 14, 2024, date of issuance: March 11, 2024), informed that Annex No. (...) to the Regulations (...) covering the list of buildings and rooms subject to video surveillance has not been updated prior to the implementation of additional surveillance in 2 rooms (...).

15) In connection with the review of documents conducted on August 28, 2024, the Medical Center, in a letter dated August 30, 2024, submitted to the supervisory authority a document titled: "Final Position of the Party on the Matter," in which it informed that in 2 rooms of the Department (...), where temporary video surveillance was installed, there were cited: "children who were transferred from sections 1 and 2 and no longer require intensive therapy. The children in these rooms are undergoing rehabilitation, learning feeding and care by their parents."

****II. Loss of memory cards from video surveillance in the Department (...).** On July 26, 2023, the Administrator made a preliminary report of a personal data breach (a supplementary report was submitted on September 15, 2023), consisting of the loss or theft of memory cards from 2 video surveillance devices that recorded images in 2 rooms of the Department (...) (the report was registered under reference number (...)). In the personal data breach report, the Administrator indicated that

cited: (...) "The Manager (...) received information from one of the doctors that the installed devices had been moved to another location in the Department and when they were checked on July 24, 2023, around 8:00 AM, it turned out that the memory cards, on which the surveillance was recorded, had been removed (the devices did not perform ongoing data recording on an external server; recording was done only on the memory card, so there is no access to a backup copy of the recordings)." At the same time, the Facility informed that as a result of the aforementioned incident, personal data of 190 individuals were compromised, including 30 patients, 60 legal representatives of patients, 97 staff members, and 3 students undergoing internships. From the explanations provided by the Administrator in letters dated October 5 and 24, 2023, and February 12, 2024, it follows that:

- 1) The Administrator has implemented Policy (...) and the related Security Procedure (...), which documents are part of the applicable System (...),
- 2) The Medical Center has a management system certificate confirming that it has introduced and applies an Information Security Management System compliant with the requirements of PN-EN ISO/IEC 27001:2017-06, undergoing annual audits (the last one in October 2022) (documents submitted in the letter dated October 5, 2023).
- 3) According to the Administrator's declaration, monitoring of compliance with procedures is carried out continuously through verification of the completeness of employee documentation, provision of the procedure content to both existing and new employees (to familiarize themselves with the applicable rules), verification of stickers with information about video surveillance on the premises of the medical facility, verification regarding the availability of processed information, and the operation of individual cameras and recorders in a continuous and automatic manner through the information system.
- 4) The Administrator organized and conducted several meetings with the Department staff. The Department staff were informed that in the event of coming into possession of memory cards or information regarding the incident, they should immediately report it to the Hospital management. Additionally, a notification of suspicion of a crime was reported, based on which an investigation was initiated by the VIII Police Station (...), case file number (...).
- 5) The Administrator, in the supplementary report form, informed that on September 15, 2023, he completed the process of notifying data subjects about the occurrence of the personal data breach, i.e., the loss of memory cards from the conducted video surveillance in the rooms (...).
- 6) In the explanations provided in the letter dated October 5, 2023, the Medical Center submitted to the supervisory authority a list of how individual subjects were notified, Policy (...), Procedure (...), an internal note regarding the IT department staff, an internal note regarding audits in the Hospital, analysis (...), and an internal note regarding the meetings conducted with the Department staff.
- 7) The Administrator, in the letter dated October 24, 2023, responded to the inquiries of the supervisory authority included in the letter dated October 11, 2023, informing that memory cards from additional monitoring devices were not subjected to encryption.
- 8) The Administrator attached to the correspondence dated October 24, 2023, a description of how the Administrator (including prior to the occurrence of the personal data breach) regularly tests, measures, and evaluates the effectiveness of technical and organizational measures aimed at ensuring the security of processed personal data.

****In the context of video surveillance) and screenshots of the software. The document in question (date of preparation: October 20, 2023) covered the technical and organizational guidelines that the video surveillance conducted at the aforementioned facility must meet. Furthermore, according to the internal note dated October 4, 2023 (submitted to the supervisory authority in a letter dated October 5, 2023), the Facility conducts annual internal audits covering, among other things, compliance with procedures regarding the applied video surveillance (the card (...)) and the protocol (...) along with the attachment were submitted in a letter dated March 11, 2024).****

- 9) The Administrator, in a letter dated February 12, 2024 (date of receipt: February 19, 2024, date of dispatch: February 13, 2024), indicated that 2 additional monitoring devices installed in the rooms of the Department (...) did not meet the requirements established and defined in the document titled "Description (...)" and were not configured with the software (...) (a system ensuring access control to the network), (...) (software monitoring a range of network parameters, as well as the operation and

integrity of servers), or (...) (vulnerability management system). The aforementioned devices were also not cited as (...) "installed in the internal computer network, data recording was done to the memory cards located in them." The Medical Center simultaneously informed that the personnel of the Department and the department (...) were responsible for the implementation of additional monitoring devices in the aforementioned rooms of the Department (...) and that their implementation did not occur according to a schedule, and no installation protocol was prepared.

10) The investigation conducted by (...) case file no. (...) was terminated by a decision dated (...) due to the failure to identify the perpetrator of the act.

11) The Administrator, in a letter dated March 11, 2024 (date of receipt: March 14, 2024, date of dispatch: March 11, 2024), responded to the inquiries of the supervisory authority included in the letter dated February 28, 2024, informing that prior to the occurrence of the personal data breach, an analysis of (...) was conducted. Furthermore, he indicated that the document in the form of the "Policy (...)" was amended by a resolution of the Management Board (...), which came into effect on (...), while the "Policy (...)" had not been updated since April 30, 2021.

In this factual state, after reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the Act of May 10, 2018, the President of the UODO is the competent authority in matters of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of this regulation and conducts proceedings regarding violations of this regulation, including based on information received from another supervisory authority or another public authority.

I. Legal basis for the processing of personal data. Article 5 of Regulation 2016/679 specifies the principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(a) of Regulation 2016/679, personal data must be processed lawfully, fairly, and in a transparent manner for the data subject ("lawfulness, fairness, and transparency"). Compliance with the aforementioned principle is necessary for the proper implementation of the accountability principle resulting from Article 5(2) of Regulation 2016/679.

According to Article 6(1) of Regulation 2016/679, the processing of personal data is lawful only if at least one of the following conditions is met: a) the data subject has given consent to the processing of their personal data for one or more specific purposes; b) processing is necessary for the performance of a contract to which the data subject is a party or to take steps at the request of the data subject prior to entering into a contract; c) processing is necessary for compliance with a legal obligation to which the controller is subject; d) processing is necessary to protect the vital interests of the data subject or another natural person; e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller; f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

It should be noted that the provision of Article 6(1)(f) of Regulation 2016/679 does not apply to the processing of personal data by public authorities in the course of performing their tasks. Article 9(1) of Regulation 2016/679 prohibits the processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade union membership, as well as the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, or data concerning health, sexuality, or sexual orientation of that person. Recital 35 of Regulation 2016/679 specifies the concept of personal data concerning health, stating that "Personal data concerning health includes all data about the health status of the data subject, revealing...

information about the past, present, or future state of the physical or mental health of the person to whom the data pertains.”

In this case, it is necessary to first analyze the legal bases indicated by the Administrator that authorize him to implement additional video monitoring in 2 rooms of the Department (...). According to the information provided in the letter dated August 17, 2023, the legal norm justifying the implementation of the aforementioned monitoring is Article 23a paragraph 1 point 2 of the Act of April 15, 2011 on medical activity (Journal of Laws of 2024, item 799) in connection with § 29 of the Regulation of the Minister of Health of March 26, 2019, on detailed requirements that should be met by the premises and equipment of entities performing medical activities (Journal of Laws of 2022, item 402).

Article 23a paragraph 1 point 2 of the aforementioned Act (in the wording applicable at the time of the violations of Regulation 2016/679 described in this decision) indicates that the manager of the entity performing medical activities may specify in the organizational regulations the method of observing the premises where health services are provided and where patients stay, in particular, bedrooms, sanitary-hygienic rooms, changing rooms, and locker rooms, if required by separate regulations – using devices that enable image recording (monitoring).

According to the Administrator's position, the separate regulations authorizing him to introduce temporary video monitoring in 2 rooms of the Department (...) under Article 23a paragraph 1 point 2 of the Act on medical activity are the legal norms contained in § 29 of the Regulation of the Minister of Health of March 26, 2019, on detailed requirements that should be met by the premises and equipment of entities performing medical activities.

According to the aforementioned provision, the installation of devices enabling the observation of patients in bedrooms is permitted if it is necessary for their treatment process and to ensure their safety. A key element in this provision is the emphasis on the necessity of introducing monitoring as an obligatory condition.

Therefore, according to the accepted assumptions, the Administrator should possess evidence, e.g., appropriate analyses, that would unequivocally indicate that only the introduction of temporary video monitoring in 2 rooms of the Department (...) would contribute to reducing the number of patient illnesses and the effective process of their treatment. It should be emphasized that only appropriate justification supported by adequate evidence would fulfill the legality condition for the introduction of image recording in accordance with the aforementioned provision.

At this point, it should be noted that the Administrator did not possess any evidence indicating that the use of video monitoring is necessary in the treatment process of patients (e.g., to cause a decrease in their illnesses) or necessary to ensure their safety, as confirmed in the letter dated February 12, 2024, quoted: “(...) The Administrator did not conduct an analysis confirming the necessity of introducing temporary monitoring in the bedrooms of the Department.”

At the same time, in the correspondence conducted, the Administrator informed that he had taken actions aimed at detecting improper and unintended behaviors causing infections in newborns in the Department; however, this did not relieve the Facility of the obligation to prove the absolute necessity of implementing temporary video monitoring in the aforementioned area. Moreover, based on the Report provided by the Administrator (...), there is no possibility to identify which factors actually influenced the reduced number of patient infections (from 25 to 18) – particularly considering the increased use of pharmacology in the relevant department, as mentioned in the Analysis (...), quoted: (...), as well as the loss or theft of memory cards from additional monitoring devices and lack of access to the recorded image.

In addition to unequivocally proving the necessity of implementing video monitoring, medical facilities are also obliged to introduce appropriate changes to the organizational regulations quoted: “in accordance with Article 23a of the Act on medical activity, the principles of monitoring should be specified in the content of the organizational regulations, thus it will be necessary to amend it if the facility expands the existing monitoring”[2]. The Patient Rights Ombudsman also expressed a similar

view in a guide issued for managers of medical facilities titled “Video Monitoring in Medical Entities,” informing that quoted: “(...) The manager of the medical entity, at the moment of implementing video monitoring in the medical entity, is obliged to introduce into the organizational regulations the method of its conduct. The obligation imposed by the legislator on the manager of the entity highlights the need to protect the rights of individuals – patients and employees of the medical entity – from unjustified use of data collected as a result of video monitoring. In this perspective, the decision to implement monitoring belongs to the manager of the medical entity, who, based on an analysis of adverse events, has knowledge adequate to assess whether video monitoring will support the staff’s work in ensuring patient safety.”

When asked by the President of the Personal Data Protection Office in a letter dated January 31, 2024, whether he had made appropriate changes to the organizational regulations (in connection with the introduction of additional monitoring devices), the Administrator incorrectly stated that quoted: “The changes to the Regulations (...) regarding video monitoring were introduced by a resolution of the Management Board (...)”. This did not constitute fulfillment by the Medical Center of the above obligation due to the fact that temporary video monitoring in 2 rooms of the Department (...) functioned from July 1 to July 23, 2023, and therefore could not be included in the resolution of the Management Board cited by the Administrator (...). Consequently, the Facility did not meet the requirements related to the introduction of additional monitoring in this regard.

Confirmation of the Administrator's passivity regarding the analyzed video monitoring is also the fact that he did not update Annex No. (...) to the Regulations of the (...) Facility, amended by the resolution of the Management Board (...), thereby failing to indicate new areas covered by video monitoring. At the same time, it should be noted that according to Chapter (...) of Annex No. 1 to the Resolution of the Management Board (...) of company X, dated (...), cited as (...) “(...)”. In the correspondence conducted by the Administrator with the supervisory authority, in a letter dated March 11, 2024, he directly admitted to irregularities in the aforementioned regard, declaring that cited as (...) “Annex No. (...) to the Regulations of the (...) Hospital, i.e., the list of buildings and rooms covered by video monitoring was not updated before the implementation of additional monitoring in the Hospital Ward.”

In light of the above, due to the demonstrated irregularities in the introduction of ad hoc video monitoring in 2 rooms of the Ward (...), the Medical Center cannot rely on Article 23a, paragraph 1, point 2 of the Act on Medical Activity as a legal basis for its actions, as the mandatory conditions for recognizing the subject monitoring as legal have not been met (i.e., the lack of adequate regulations in the organizational regulations and the failure to demonstrate the necessity of implementing video monitoring).

At the same time, it should also be emphasized that the analysis of the provisions of the Act on Medical Activity (in the wording in force at the time of the violations of Regulation 2016/679 described in this decision), as well as the provisions of other legal acts relating to this matter, clearly indicates the existence of an obligation on the part of medical facilities to respect the intimacy and dignity of patients in connection with the provision of medical services, which obligation the Administrator failed to uphold towards his patients by installing ad hoc video monitoring.

Consequently, although the obligation in this regard was explicitly formulated in the provisions of the Act on Medical Activity only as a result of its amendment, which came into force on September 6, 2023, it cannot be considered that earlier (and thus also during the operation of ad hoc video monitoring in the aforementioned rooms) the Medical Center was exempt from taking them into account when providing services (which will be discussed further in this decision).

In this matter, the Provincial Administrative Court in Warsaw also expressed its opinion in the judgment of September 13, 2019, case file VII SA/Wa 1545/19, LEX No. 2728947, in which one of the parties to the administrative proceedings was the Patients' Rights Ombudsman, cited as “The Court in the panel reviewing this case fully shares the position of the authority, which is based on doctrine, that the intimacy of the patient, i.e., closeness, should relate to all feelings and actions associated with the provision of health care services. Such understood intimacy consists of: caring for the patient's

well-being, respect for the patient, understanding their situation, exchanging intimate information, considering the patient as a subject of the highest value. Intimacy relates both to the patient themselves - to the sphere of their exclusively personal, confidential life, as well as to relationships with other people, based on warmth and closeness. Violation of intimacy is associated with a sense of shame. The sphere of an individual's intimacy should be subject to special protection, according to which only the individual can dispose of this sensitive sphere of feelings."

With the aim of a detailed legal analysis regarding the introduction of ad hoc video monitoring by the Medical Center, it is necessary to refer to Annex No. 1 IV titled "Delivery Room" point 4 of the Regulation of the Minister of Health of March 26, 2019, on detailed requirements that should be met by the premises and equipment of entities performing medical activity, which directly relates to the possibility of applying video monitoring in premises designated for mothers and newborns. According to this provision, the delivery room should contain at least one room designated for mothers and the newborn in the first hours of life, after complicated births, in which direct observation or observation using cameras equipped with auto-start functions is ensured, particularly the possibility of observing the face. This provision may serve as a legal basis for such a form of observation only in situations where the health condition of newborns, due to birth complications, is unstable and may threaten their life or health.

In the case of the implementation of video monitoring by the Administrator in 2 rooms of the Ward (...) (from July 1 to July 23, 2023), this legal basis cannot be applied, as according to the "Final Position of the Party in the Matter" provided in the letter dated August 30, 2024, in the premises where ad hoc video monitoring was installed, there were cited: "children who were transferred from sections 1 and 2 and no longer require intensive therapy. The children in these rooms are undergoing rehabilitation, learning to be fed and cared for by their parents" – thus confirming that the implementation of monitoring was not aimed at observing newborns whose life or health was at risk.

In a letter dated August 17, 2023, the Administrator also indicated that the legal basis justifying the implementation of ad hoc video monitoring in 2 rooms of the Ward (...), in addition to Article 23a, paragraph 1, point 2 of the Act on Medical Activity, is also Article 6, paragraph 1, letter f) of Regulation 2016/679 and Article 222

Labor Code Act.

As indicated above, in the case of medical facilities, the rules for implementing video surveillance (and processing personal data related to it) are governed by the provisions of the Act on Medical Activity. An administrator who does not comply with the principles of its implementation arising from these provisions (as is the case with the Medical Center) cannot invoke other grounds for processing personal data, including the ground specified in Article 6(1)(f) of Regulation 2016/679, to justify its application. It should also be noted that due to the applied video surveillance in 2 rooms of the Department (...), health data were also processed, and these can only be processed after meeting one of the grounds specified in Article 9(2) of Regulation 2016/679. For obvious reasons, the ground for processing such data mentioned in Article 6(1)(f) of Regulation 2016/679 cannot be recognized as valid.

It should be pointed out that the provisions of Regulation 2016/679 established fundamental principles for processing personal data, including the principle of legality, formulated in Article 5(1)(a) of Regulation 2016/679. The principle of legality, "also referred to as the legality of data processing, means the requirement to comply with the norms established in legal provisions. The principle of lawful processing of data has a broad scope, not only concerning the provisions of the commented regulation but also regarding provisions contained in other normative acts. (...) Among the provisions concerning data processing, particular importance is given to the requirements relating to the legality of processing (also referred to as the so-called grounds for the admissibility of data processing or the grounds for the legality of data processing), specified in the provisions of Articles 6, 9, and 10 of the commented regulation. These provisions indicate the cases when data processing is legally permissible (to put it simply: when it is lawful to process personal data)" (P. Fajgielski, Commentary on Regulation No. 2016/679 on the protection of natural persons in relation to the processing of personal data and on the

free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation), [in:] General Data Protection Regulation. Personal Data Protection Act. Commentary).

It should therefore be emphasized that the use of the ground expressed in Article 6(1)(f) of Regulation 2016/679 requires an in-depth analysis of the specific factual situation. First of all, it is necessary to assess whether there is a legitimate interest on the part of the administrator or a third party. According to the position of W. Chomiczewski expressed in the commentary on Regulation 2016/679 titled "Legitimate Interest as a Ground for Legalizing Data Processing – Concept" (LEX/el. 2018), "For the realization of the objective resulting from such an understood interest of the administrator, the processing must be necessary. This means a reasonable need for achieving this objective. It should be assessed both in relation to processing in general and to the processing of specific categories of personal data. In the next step, it should be assessed whether the planned realization of the objective resulting from the legitimate interest of the administrator or a third party may infringe upon the interests, fundamental rights, or freedoms of the data subject that require the protection of personal data. Processing based on Article 6(1)(f) of the General Regulation will not be permissible if, after the above assessment, it turns out that the interests, fundamental rights, and freedoms of the data subject that require the protection of personal data are superior to the legitimate interests of the administrator or a third party."

Taking the above into account and considering the previous findings regarding the analyzed case, it should be deemed unfounded for the Administrator to cite Article 6(1)(f) of Regulation 2016/679 as the legal basis authorizing the implementation of additional video surveillance in the form of 2 monitoring devices in 2 rooms of the Department (...). The Administrator's reference to Article 222 of the Labor Code as the legal basis authorizing the introduction of temporary monitoring in 2 rooms of the Department (...) should also be considered misguided. According to the content of the aforementioned provision, the use of monitoring in the workplace is permitted if it is necessary to ensure the safety of employees or the protection of property or the control of production or the confidentiality of information whose disclosure could expose the employer to harm.

The issue of the principles of implementing video surveillance by the employer in the workplace was raised in the judgment of the European Court of Human Rights of October 17, 2019, *López Ribalda and Others v. Spain* [Grand Chamber], application nos. 1874/13 and 8567/13, which states that "the employer may implement video surveillance measures in the workplace. These criteria should be applied, taking into account the specifics of the employment relationship and the development of new technologies that may enable increasingly intrusive measures into the private lives of employees. In this context, to ensure the proportionality of video surveillance measures in the workplace, national courts should consider the following factors when weighing various competing interests: - whether the employee was informed about the possibility of the employer implementing video surveillance measures and the application of such measures: although in practice employees can be informed in various ways – depending on the specific factual circumstances of each case, notification should generally be clear regarding the nature of the monitoring and occur prior to its implementation; - the scope of monitoring conducted by the employer and the degree of intrusion into the employee's privacy: in this...

****Regarding the need to consider the scope of privacy****

in a monitored location, along with
any restrictions regarding time and area, as well as
the number of individuals having access to the results; - whether
the employer presented legitimate reasons
justifying the monitoring and its scope: the more
intrusive the monitoring, the more serious justification
is required; - whether it was possible to implement a
monitoring system based on less intrusive methods
and means: in this regard, an assessment should be made
in light of the specific circumstances of each case, whether

the goal pursued by the employer could have been achieved without intruding on the privacy of employees to such an extent; - the consequences of monitoring for the employees subjected to it: it should be taken into account, in particular, the employer's use of the monitoring results and whether these results were used to achieve the declared purpose of this measure; - whether the employee was provided with appropriate guarantees, especially when the operation of the employer's monitoring is intrusive: such guarantees may take the form, among others, of providing interested employees and staff representatives with information about the installation and scope of monitoring, declaring such a measure to an independent body, or the existence of the possibility to file a complaint.

****The aspect of respecting the dignity of employees in relation**** to the introduction of video monitoring in the workplace is the subject of many publications in the doctrine. In this regard, K. Jaśkowski has also expressed his views [in:] E. Maniewska, K. Jaśkowski, Labor Code. Commentary, 11th ed., Warsaw 2019, art. 22(2), art. 22(3), noting that: "Undoubtedly, monitoring the work of employees constitutes an interference with their right to privacy. The interpretation of the commented provisions should therefore be made with consideration of the need to balance these conflicting values and interests of both parties to the employment relationship, which means that monitoring as a form of control of the employee by the employer must take into account the need to respect the personal rights of employees, including the right to privacy. In this regard, the standards set by the jurisprudence of the European Court of Human Rights regarding Article 8 of the ECHR should also be considered (see, in particular, judgments: of January 9, 2018, 1874/13 and 8567/13, López Ribalda and Others v. Spain with the opinion of M. Mrowicki, LEX No. 2418052; of November 28, 2017, 70838/13, Antović and Mirković v. Montenegro; LEX No. 2398411; judgment of the Grand Chamber of September 5, 2017, 61496/08, Bărbulescu v. Romania with the opinion of M. Mrowicki, LEX No. 2347233; of April 3, 2007, 62617/00, Copland v. the United Kingdom, LEX No. 527588; of August 2, 1984, 8691/79, Malone v. the United Kingdom, LEX No. 80974)."

According to the information provided by the Administrator in the correspondence conducted so far, the implementation of the monitoring in question was not in any way related to ensuring the safety of the staff or the protection of property, as the installation of monitoring devices was justified by the quote: "exclusively for reasons related to the necessity of eliminating and preventing in the future situations concerning a higher than usual number of symptoms of infections in newborns" (Administrator's declaration in the letter dated March 11, 2024). In light of the above, the legal basis indicated by the Administrator

does not apply to the factual state established during the administrative proceedings. Given these discrepancies, one might get the impression that the Administrator was aware of the unlawfulness of his actions – thus, his actions were intentional and deliberate. At this point, it is worth citing the position of the Undersecretary of State in the Ministry of Health expressed in the letter dated June 3, 2019, ref. SZDL.073.3.2019.CP, which was a response to the inquiry of the Patient Rights Advocate to the Minister of Health (ref. RzPP-DSD.420.81.2019 RzPP-DSD.420.81.2019.JN.PGE) dated May 14, 2019, regarding video monitoring in entities performing medical activities, stating: “However, allowing video monitoring (constant observation of the patient) for the purpose of controlling medical staff and for other (organizational) purposes not directly related to the process of treating the patient and ensuring his safety seems risky. Such recordings, i.e., captured images of the patient (e.g., in intimate situations) would be a ‘by-product’ of the observation of medical staff and the application of the standards adopted in the given hospital. In this case, there would be an excessive risk of treating the patient as an object and violating the principles of respecting his intimacy, dignity, and privacy.”

Considering the above findings, the position of the President of the Personal Data Protection Office (UODO) is justified, that in the analyzed case, the video monitoring applied by the Administrator in 2 rooms of the Department (...) was introduced without meeting the conditions provided for in the applicable legal regulations. There is no doubt about the fact that the personal data of patients subject to this video monitoring constituted a special category of personal data (i.e., health data), subject to special protection regulated under Article 9(1) of Regulation 2016/679, which the Administrator effectively failed to comply with. It should be noted that during the proceedings, it was not established that the temporary video monitoring in 2 rooms of the Department (...) also recorded sound.

In analyzing this matter, it is crucial to emphasize and clearly articulate the fact that the video monitoring applied in 2 rooms of the Department (...) was improperly introduced, i.e., in violation of applicable regulations, and seriously endangered the proper realization of the rights granted to citizens under the Constitution of the Republic of Poland of April 2, 1997 (Journal of Laws No. 78, item 483, as amended). This is particularly important, as according to Article 47 of the Constitution of the Republic of Poland, everyone has the right to legal protection of their private life, family life, honor, and good name.

in the name of and to decide about their personal life. It should be noted that the right to privacy is one of the fundamental human rights, and its protection is a fundamental element of the system of values. At the same time, the consequences of violations of unauthorized access to information can be pursued under civil, criminal, and administrative law. The Appellate Court in Warsaw also expressed its opinion on this matter in a judgment dated November 19, 2019, case file VI ACa 397/18, indicating that "The right to privacy in light of constitutional regulations is primarily perceived through the prism of individual autonomy derived from the dignity-based concept of the human person, which, according to Article 30 of the Constitution of the Republic of Poland, is the source of all rights and freedoms. The right to protection of private life, which is the subject of protection under Article 47 of the Constitution of the Republic of Poland, means the individual's right to decide about their personal life. An individual, as a subject endowed with the autonomy of will, has the right to independently define the scope of their privacy, in particular to delineate the boundaries of accessibility of their personal life and information about it to others. The right to privacy in the aspect of the individual's informational autonomy means the entitlement to decide which information concerning them will be available to third parties." In correlation with the aforementioned provision, there is also Article 51 of the Constitution of the Republic of Poland, according to which every citizen has the right to the protection of personal data. According to the Appellate Court in Warsaw (judgment dated August 23, 2018, case file VI ACa 1927/16), "The right to the protection of personal data is an emanation of the right to informational autonomy, allowing the individual to control, to a certain extent, the manner and scope of the information concerning them that is made available. In the event of its violation, depending on the specific circumstances of the case, there may be an infringement of certain personal goods, subject to a separate regime, protected by the provisions of the Constitution, as well as particularly within the framework of the regulations of Articles 23 and 24 of the Civil Code."

In addition to the rights guaranteed by the Constitution of the Republic of Poland, it is worth mentioning Article 20, paragraph 1 of the Act of November 6, 2008 on Patient Rights and the Patient Rights Ombudsman (Journal of Laws of 2024, item 581), which states that the patient has the right to respect for their intimacy and dignity, particularly during the provision of health services. At this point, it is particularly important to emphasize that the video monitoring introduced by the Administrator in 2 rooms of the Department (...) recorded images showing both newborns and their mothers, allowing for the preservation of their likenesses even during intimate activities, including feeding the children or their care – which contradicts the obligation to respect the intimacy and dignity of the patients mentioned above. In detail regarding the interpretation of the aforementioned legal norm, P. Grzesiewski expressed himself [in:] Patient Rights and the Patient Rights Ombudsman. Commentary, ed. D. Karkowska, Warsaw 2021, Article 20. "At the outset of the analysis concerning the values protected by Article 20, paragraph 1 of the Patient Rights Act, it should be noted that this provision regulates two separate rights – the right to respect for dignity and the right to respect for intimacy. Dignity and intimacy have not been defined anywhere. In searching for the meaning of these concepts for the purposes of this analysis, one should primarily refer to the jurisprudence of the Constitutional Tribunal. Dignity plays a primary role, as the foundation of all freedoms and rights. Intimacy is related to it, as well as to the right to privacy. These terms are subjectively connected, and their scopes overlap. In the case of dignity, Article 30 of the Constitution of the Republic of Poland is of fundamental importance, under which the inherent and inalienable dignity of a human being is the source of the freedoms and rights of man and citizen. The significance of human dignity has also been expressed by the legislator in the preamble to the fundamental law, calling on all who apply the Constitution of the Republic of Poland to do so while caring for the preservation of the inherent dignity of man. Dignity is inviolable, and its respect (as previously indicated) and protection is the duty of public authorities. To determine the subject and scope of protection established by Article 20, paragraph 1 of the Patient Rights Act, it is important that human dignity cannot be considered solely in one conceptual plane. The jurisprudence of the Constitutional Tribunal has established a two-dimensional perception of constitutionally guaranteed human dignity – firstly, human dignity, as a transcendent value, primary to other rights and freedoms of man (for which it is the source), inherent and inalienable – accompanies man always and cannot be violated either by the legislator or by specific acts of other entities." The

same position was presented in the judgment of the Supreme Administrative Court dated February 25, 2020, case file II OSK 3837/19, cited (...) "Respect for human dignity consists of a number of values. From the perspective of patient rights, respect for dignity includes the right to intimacy. An expression of this right to respect for intimacy is such action by the entity providing health services that does not violate this sphere. A breach occurs when a system of monitoring patients is introduced that exceeds the boundaries set by law [...]. The patient's right to protection of intimacy and dignity includes the right to be informed about monitoring and the right to express or refuse to express consent to monitoring." Remaining on the topic of respect for dignity, it is worth referring to the report (result of the inspection conducted in the years 2019-2023) of the Supreme Audit Office entitled "Observance of Patient Rights in the Health Protection System" (case file KZD.430.1.2024, No. 15/2024/P/23/047/KZD) published on September 19, 2024, which indicates numerous irregularities in the observance of the right to respect for intimacy and dignity of patients during the provision of health services. The aforementioned inspection covered its scope.

included the issue of video surveillance, the conclusions of which highlight the problem related to the recording of images in healthcare entities. The Supreme Audit Office emphasized that: "The unjustified, excessive use of video surveillance is a limitation of patient privacy. The findings of the audit indicate that video surveillance covered rooms where the regulations in force during the audit period did not foresee the presence of cameras, and the internal regulations concerning video surveillance were sometimes prepared inaccurately. Irregularities in this regard were found in 18% of entities."

In summary, the arguments analyzed above clearly underscore the fact that the Administrator, during the period of applying ad hoc video surveillance in the wards of the (...) processed personal data of patients, which also constitutes a special category of personal data (i.e., data concerning health) in violation of applicable legal provisions, thus breaching the provisions of Article 6(1) and Article 9(1) of Regulation 2016/679, and consequently violating the principle of lawfulness expressed in Article 5(1)(a) of Regulation 2016/679 and the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

II. Information Obligation. The President of the Personal Data Protection Office (UODO) also found that the Administrator violated Article 13(1) and (2) of Regulation 2016/679, which pertains to the information obligation towards individuals whose personal data are being processed. According to Article 13(1) of Regulation 2016/679, the administrator is obliged to provide individuals from whom personal data has been collected with the following information: their identity and contact details and, where applicable, the identity and contact details of their representative, where applicable - the contact details of the data protection officer, the purposes of processing personal data, and the legal basis for processing, if the processing is based on Article 6(1)(f) – legitimate interests pursued by the administrator or by a third party, information about the recipients of personal data or categories of recipients, if any, where applicable - information about the intention to transfer personal data to a third country or an international organization and about the determination or lack of determination by the Commission of an adequate level of protection or in the case of transfer referred to in Articles 46, 47, or 49(1) second paragraph, a mention of appropriate or suitable safeguards and the possibility of obtaining a copy of the data or the place where the data will be made available.

Furthermore, according to Article 13(2) of Regulation 2016/679, in addition to the information specified in paragraph 1 of the aforementioned article, the administrator is obliged to provide individuals from whom personal data has been collected with information necessary to ensure the fairness and transparency of processing: the period for which the personal data will be stored, and where that is not possible, the criteria used to determine that period, information about the right to request from the administrator access to personal data concerning the data subject, their rectification, erasure, or restriction of processing or the right to object to processing, as well as the right to data portability, if the processing is based on Article 6(1)(a) or Article 9(2)(a) – information about the right to withdraw consent at any time without affecting the lawfulness of processing based on consent before its withdrawal, information about the right to lodge a complaint with a supervisory authority, information on

whether the provision of personal data is a statutory or contractual requirement or a requirement necessary to enter into a contract and whether the data subject is obliged to provide the data and what the possible consequences of not providing the data are.

The supervisory authority, after analyzing the content of the information clause and the explanations provided by the Administrator in this regard, found that the Medical Center did not fulfill the information obligation arising from the aforementioned provision of Regulation 2016/679 towards individuals whose data were subject to ad hoc video surveillance in 2 wards of the (...). According to point 4 of the information clause submitted in the letter dated August 17, 2023, it states: "video surveillance covers the area of the building located at (...) in K. (publicly accessible rooms and key rooms, in accordance with applicable regulations) and the area around this building." The wording formulated in this manner does not provide full and exhaustive information to the data subjects regarding the actual area covered by video surveillance in the Facility, particularly it does not directly indicate that surveillance is also applied in the patient rooms. It should be firmly emphasized that during the application of video surveillance, a key element is the precise and accurate indication of the rooms where monitoring devices are installed. The term "key rooms" used by the Administrator is too vague and may raise interpretative doubts. The Administrator must also remember that the information in this regard is intended for the individuals whose data are concerned, and therefore must be understandable to them. In other words, the content of the information clause should clearly indicate in which rooms video surveillance has been installed. The use of the term "key rooms" does not meet this requirement, as the individuals concerned do not know (and do not have to know) the conceptual scope of this term, i.e., what rooms the Administrator considers to be key.

According to the Medical Center's statement expressed in the letter dated October 24, 2023, it states: "The aforementioned information clause was intentionally constructed in such a way, i.e., with a general description of the rooms that are not publicly accessible, as..."

"key rooms, in accordance with applicable regulations," to meet the requirement of conciseness of the information provided as established in Article 12 of the GDPR, referred to in Article 13 of the GDPR, i.e., the information clause. If a solution were applied in which all rooms subject to monitoring were enumeratively listed in the content of the information clause, its volume would be significantly larger, which would not comply with the aforementioned principle of conciseness of information, and furthermore, it would become opaque, given that the mere list of monitored rooms would fill most of its content. At this point, it should be emphasized that the Administrator, through the lens of the analyzed case, has overinterpreted and distorted Article 12(1) of Regulation 2016/679, as the term "key rooms," as demonstrated above, is not understandable to the data subjects, and thus does not meet the requirement of transparent information in accordance with this provision of Regulation 2016/679. It should be noted here that there cannot be situations in which the Administrator, invoking the principle of conciseness and transparency, fails to provide data subjects with complete and reliable information that is also understandable to them regarding the processing of their personal data. It should be emphasized that for data subjects, one of the paramount pieces of information they would like to obtain regarding the monitoring applied in the medical facilities they use is information about the specific rooms in which it is applied. From the perspective of the individuals whose data is concerned, alongside the legal basis for processing, this is the most valuable information. Justifying the Administrator's omissions and irregularities in the implementation of the provisions of Article 13 of Regulation 2016/679 in the manner described above is therefore unacceptable. It is worth emphasizing that the Administrator, considering the volume of the information provided, could have applied the layered information clause proposed by the Article 29 Working Party in the Guidelines on Transparency under Regulation 2016/679 of November 29, 2017. Layered fulfillment of the information obligation can be applied in various forms of communication, including digital, telephone, or personal, and under various processing bases. The issue in question has also been expressed in the Guidelines of the European Data Protection Board 3/2019 on the processing of personal data through video devices adopted on January 29, 2020, cited as (...) "In light of the amount of information that must be provided to the data subject, data controllers may adopt a layered approach if they decide to use a combination of methods to ensure transparency (WP260, para. 35; WP89, para. 22). Regarding video

surveillance, the most important information should be placed on the warning sign itself (first layer), while further mandatory details may be provided through other means (second layer)." (p. 28, para. 111).

At the same time, remaining on the topic of the information obligation, it should be pointed out that information about the video surveillance applied was placed (via an information sticker) only on the main doors of the Department (...), and not directly by the rooms with installed temporary monitoring. The above may mislead both patients, visitors of patients, and employees of the facility regarding the actual area covered by the monitoring. The President of the UODO twice (letters dated September 25 and October 11, 2023) inquired with the Administrator whether the information obligation regarding the video surveillance applied in the aforementioned rooms of the Department (...) had been fulfilled concerning the individuals subject to monitoring, but he did not receive an adequate response. In letters dated October 5 and 24, 2023, the Medical Center vaguely emphasized that, cited as (...) "Users of the rooms where video monitoring was applied, including patients, visitors of patients, and Hospital staff, were informed about the use of video monitoring on the premises of the Hospital through stickers located on the Hospital building in places where monitoring was applied, containing the said information and referring to the content of the information clause regarding the use of video monitoring, through a QR code redirecting to a website with the relevant clause." Meanwhile, as demonstrated above, such presented information did not fulfill its primary purpose, as the individuals whose data is concerned were not aware that the monitoring also covered 2 rooms of the Department (...).

It is also necessary to consider the nature of the video monitoring applied. The initial information indicated in the article stated that the introduced video monitoring in 2 rooms of the Department (...) did not have a visible form. According to the information, both employees and patients were not informed about the implemented monitoring. An additional aspect supporting the aforementioned statement is the fact that the Administrator used clocks with image recording functionality (i.e., a camera mounted in the clock allowing for image recording) to carry out the aforementioned actions, which he informed the supervisory authority about in a letter dated August 17, 2023. In the same correspondence, the Administrator indicated that the use of such monitoring devices allowed for quick action and installation (considering the need to promptly take appropriate steps due to the threat to the safety of newborns), cited as (...) "unlike solutions with wired cameras, whose installation would require a longer time and undertaking more advanced activities, including construction work, which, due to the nature of the Department and the potential inconvenience to its normal functioning, was excluded at that time."

Furthermore, it should be emphasized that the implementation of temporary monitoring by installing 2 additional cameras did not occur on the basis of...

****Schedule and Protocols****

The schedule has not been prepared in this regard, nor has a protocol concerning their installation been drawn up. Another factor opposing the transparent nature of the applied video monitoring is the lack of knowledge among the facility's staff about the introduced actions. According to the provisions of the "Policy (...)" effective from April 1, 2019, cited as (...) "(...)". The Administrator, when asked by the President of the Personal Data Protection Office (UODO) in a letter dated February 28, 2024, whether he informed employees before implementing this monitoring about the introduction of new areas covered by monitoring in accordance with the applicable "Policy (...)" section "Principles (...)", responded evasively to the aforementioned issue in a letter dated March 11, 2024, providing an inadequate answer cited as (...) "The employees of the company were informed about the resolution adopted by the management of X in (...) regarding the introduction of changes to the Regulations (...) concerning the implementation of video monitoring on the premises of the workplace as of July 1, 2021. This information was communicated to all employees of the Hospital via email after the aforementioned resolution was adopted" (email sent to all employees of the facility on August 25, 2021). It is worth recalling that ad hoc video monitoring in the rooms of the Department (...) was used from July 1 to July 23, 2023; therefore, the information provided to employees in 2021 cannot, by necessity, cover the expansion of monitoring that took place in 2023.

At this point, it is worth mentioning the document titled "Guidelines of the President of the Personal

Data Protection Office regarding the use of video monitoring Version 1 June 2018," in which it is emphasized that cited as (...) "The provisions of the GDPR and national regulations do not allow monitoring to be conducted using hidden cameras. Only law enforcement and special services conducting activities based on laws regulating their operations have the authority to conduct covert monitoring. The use of hidden cameras may be considered an excessive form of data processing, associated with administrative and civil liability, and even criminal liability."

Thus, analyzing the collected evidence, it must be unequivocally stated that the video monitoring applied in the aforementioned area was covert monitoring, of which neither patients nor the facility's staff were informed. At the same time, it should be emphasized that the Administrator was also aware of the questionable form of implementing this monitoring, declaring this fact in a letter dated February 12, 2024, cited as (...) "We are aware of the imperfections of the applied method of ad hoc monitoring."

In summary of the above considerations, the President of the UODO, based on the collected evidence, stated that the Medical Center failed to fulfill its informational obligation towards individuals subjected to ad hoc video monitoring in the rooms of the Department (...), thereby violating its obligations arising from Article 13(1) and (2) of Regulation 2016/679.

****III. Principles of Data Processing Security****

Article 5(1)(f) of Regulation 2016/679 indicates that personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity"). According to Article 5(2) of Regulation 2016/679, the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability").

The specifics of the confidentiality principle mentioned above are further detailed in the provisions of this regulation, including Article 24(1) of Regulation 2016/679, which states that taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with Regulation 2016/679 and to be able to demonstrate this. These measures are reviewed and updated as necessary. As stated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity are factors that the administrator is obliged to consider in the process of building a data protection system, particularly in light of the other obligations specified in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679.

The indicated provisions specify the confidentiality principle defined in Article 5(1)(f) of Regulation 2016/679, and adherence to this principle is necessary for the proper implementation of the accountability principle arising from Article 5(2) of Regulation 2016/679. According to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity arising from processing, the administrator—both when determining the methods of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the necessary safeguards for processing to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the administrator is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights and freedoms of natural persons of varying likelihood.

****Occurrences and Severity of Threats.**** The provision specifies that when deciding on technical and organizational measures, one must take into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, as well as the risk of

infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. From the cited provision, it follows that determining appropriate technical and organizational measures is a two-step process.

1. ****Risk Assessment.**** First and foremost, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679. Subsequently, it is necessary to establish what technical and organizational measures will be appropriate to ensure a level of security commensurate with that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure confidentiality, integrity, availability, and resilience of processing systems and services on an ongoing basis, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as well as regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed.

2. ****Scope of Personal Data Processing.**** Considering, in particular, the scope of personal data processed by the Controller, contained on lost or stolen memory cards that were placed in video surveillance devices (i.e., images and health-related data), in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Controller was required to take actions ensuring an appropriate level of data protection by implementing appropriate technical and organizational measures to ensure the security of the processed personal data. The nature and type of these actions should result from the conducted risk analysis, in which vulnerabilities related to the utilized resources should be identified, along with the threats arising from them, and then appropriate security measures should be determined. An incorrect assessment of the level of risk prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence. The consequence of the above was the loss of control over the personal data of individuals whose data was on the lost or stolen memory cards, which contained recordings from video surveillance installed in 2 rooms of the Department (...).

It should also be emphasized that due to the nature and specificity of the Department (...), the patients included children (newborns). This is significant because at the time of the loss or theft of the memory cards containing images of newborn patients, one cannot exclude the possibility of unauthorized individuals publicizing the obtained images on the internet. According to the ongoing educational campaign and the published guide titled "The Image of a Child on the Internet," the President of the UODO refers to the risks associated with the mentioned sharing of images of children, such as cyberbullying or the use of content involving them for criminal purposes.

It should be noted that Regulation 2016/679 introduced an approach in which risk management constitutes the foundation of actions related to the protection of personal data. Risk management is a continuous process that requires the data controller not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as take into account the nature of the organization and the mechanisms used for processing personal data. The Controller must therefore conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Specific measures and procedures regarding security are not indicated to the Controllers. Conducting a detailed analysis of the data processing processes and assessing the risk is

an obligation of the Controller, who should then, based on such analysis, apply such measures and procedures that will be adequate to the estimated risk.

Therefore, it is the appropriately conducted risk assessment that provides the controller with the ability to determine and implement technical and organizational measures that will eliminate or at least significantly reduce the established level of risk of materializing identified threats to the processed personal data. The risk assessment conducted by the controller should be documented and justified by the factual state existing at the time of its conduct. The main factors constituting a proper assessment, which...

should be taken into account during the analysis, namely the characteristics of the processing processes, assets, vulnerabilities, threats, and current security measures. It should be noted that significant factors in assessing risk also include the scope and nature of the personal data processed by the data controller, as these will determine any potential negative consequences for the individual at the time of a breach of their personal data protection.

The risk analysis provided by the Administrator in a letter dated March 11, 2024, in the form of a document titled "Analysis (...)" (date of preparation not specified) raises many doubts. The risk analysis conducted by the Medical Center was improperly prepared, as it did not detail the identified vulnerabilities, and the threats associated with the processing of personal data in connection with the conducted video monitoring were not correctly and exhaustively identified. Consequently, the aforementioned risk analysis did not specify the security measures aimed at mitigating the risks associated with the video monitoring conducted by the Facility.

Analyzing the submitted document, it should be stated that among the provisions contained in the risk analysis, the Administrator did not indicate the possibility of an event involving the loss or theft of external data carriers (i.e., memory cards). Therefore, it must be assumed that the Medical Center inadequately conducted the aforementioned analysis, thus failing to consider the relevant risks associated with the video monitoring conducted at the Facility. The Administrator thus neglected to conduct a risk analysis for the situation that led to the reported breach of personal data protection submitted to the President of the UODO, which should be considered non-compliant with the provisions of Regulation 2016/679 cited above. Meanwhile, as indicated by the WSA in Warsaw in its judgment of May 13, 2021, case no. II SA/Wa 2129/20, "The data controller should, therefore, conduct a risk analysis and assess what threats it is facing." The WSA in Warsaw expressed a similar view in its judgment of October 5, 2023, case no. II SA/Wa 502/23. Furthermore, in its judgment of February 27, 2024, case no. II SA/Wa 1404/23, the WSA in Warsaw stated that "there is no doubt that in order for the risk analysis to be conducted properly, the threats that may arise in the data processing process must be correctly defined by the administrator."

It should also be noted that the Administrator had implemented a "System (...)," which also included the procedure (...). The "Procedure (...)" has been in effect in the organization since April 1, 2019, and according to the Administrator's declaration contained in the letter dated March 11, 2024, cited (...) "the document 'Procedure (...)' has not been updated since April 30, 2021," when the last modification of the aforementioned document took place. At the same time, according to the records of the analyzed procedure, the section "Security (...)" point (...) cited (...) "(...)."

In light of the above, the President of the UODO twice sent letters dated October 11, 2023, and February 28, 2024, to the Administrator inquiring whether the lost (i.e., misplaced or stolen) memory cards, on which the video image from the installed cameras was recorded, were cryptographically secured in accordance with the applicable guidelines in the organization. The Medical Center, in letters dated October 24, 2023, and March 11, 2024, responded and confirmed that cited (...) "The memory cards from additional monitoring devices were not cryptographically secured."

Also significant for this matter is the document titled "Description (...)" (date indicated on the document: October 20, 2023), which was submitted to the supervisory authority in a letter dated October 24, 2023. According to the principles outlined in the aforementioned document: - the internal computer network, in which monitoring is installed, has segmentation and access control implemented through

software (...), - monitoring the operation of individual cameras, recorders, and all other devices, software, and services essential for the proper functioning of the company is carried out by monitoring software (...), which, in addition to notifying about any anomalies in the monitored resources, also records all events, - additional solutions implemented in the network that enhance the level of security in the processing of data in the area of video monitoring include vulnerability management systems (...) and security systems (...) along with the service (...).

At the same time, it should be noted that when asked whether the additional monitoring devices installed in the relevant rooms of the Department (...) were configured with the software used in the organization (...), (...) and (...), and whether these cameras were installed in (...) the Administrator responded negatively, indicating that cited (...) "the two additional monitoring devices installed in the rooms of the Department (...) did not meet the requirements established in the document attached to the last letter, i.e., 'Description (...)' and the additional devices were not configured with the software (...), (...) or (...)."

Thus, it should be indicated that according to the established facts, the Administrator did not comply with its own regulations and procedures related to the implementation of video monitoring and securing data carriers, of which it was fully aware. The Provincial Administrative Court in Warsaw also addressed this issue in its judgment of January 19, 2021, case no. II SA/Wa 702/20, in which it stated that "(...) the data controller should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures their appropriate security and confidentiality."

proceeding, decided to impose an administrative fine on the Administrator for the violations of the provisions of Regulation 2016/679.

IV. Administrative Monetary Penalties

A. Behaviors Subject to Administrative Monetary Penalties

Application of Article 83(3) of Regulation 2016/679.

Considering the above findings and the identified violations of the provisions of Regulation 2016/679, the President of the Personal Data Protection Office (UODO), exercising the authority granted to him under Article 58(2)(i) of Regulation 2016/679, which states that each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this Regulation, an administrative monetary penalty pursuant to Article 83(4)(a) and (5)(a) and (b) of Regulation 2016/679, taking into account the circumstances established in the subject proceeding, decided to impose an administrative fine on the Administrator for the violations of the provisions of Regulation 2016/679.

The decision to impose the fine was based on the assessment of the severity of the infringement, the intentionality or negligence of the Administrator, the degree of cooperation with the supervisory authority, and the previous infringements committed by the Administrator.

The President of UODO also considered the measures taken by the Administrator to mitigate the damage suffered by the data subjects, as well as the financial situation of the Administrator.

In light of the above, the President of UODO determined that the imposed fine should reflect the seriousness of the infringement and serve as a deterrent to prevent future violations.

The amount of the fine was calculated in accordance with the criteria established in Article 83(1) of Regulation 2016/679, taking into account the nature, gravity, and duration of the infringement, as well as the number of data subjects affected and the level of damage suffered by them.

The President of UODO also took into account the fact that the Administrator had previously been warned about the necessity of implementing adequate technical and organizational measures to ensure the security of personal data.

The final decision regarding the amount of the fine will be communicated to the Administrator in writing, along with the reasoning for the decision and the right to appeal.

This decision is subject to review by the competent administrative court in accordance with the applicable legal provisions.

The President of UODO emphasizes that the protection of personal data is of utmost importance and that all entities processing personal data must comply with the provisions of Regulation 2016/679 to ensure the rights and freedoms of data subjects.

proceeding found that in the case at hand, there were grounds justifying the imposition of an administrative monetary penalty on the Administrator. The administrative proceeding conducted by the President of the UODO serves to control the compliance of data processing with the provisions on the protection of personal data and is aimed at issuing an administrative decision in order to apply the corrective powers specified in Article 58(2) of Regulation 2016/679.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject to an administrative monetary penalty of up to EUR 10,000,000, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable.

According to Article 83(5)(a) and (b) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, and the rights of data subjects, referred to in Articles 12-22, are subject to an administrative monetary penalty of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable.

Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty shall not exceed the amount of the penalty for the most serious violation.

In connection with the finding of multiple violations of the provisions of Regulation 2016/679 in this case (Article 6(1), Article 9(1), Article 13(1) and (2), Article 24(1), Article 25(1), and Article 32(1) and (2), as well as Article 5(1)(a) and (f) and Article 5(2)), the President of the UODO is entitled to apply one or more corrective measures specified in Article 58(2) of Regulation 2016/679. Among these powers of the supervisory authority is the power to impose, in addition to or instead of other measures referred to in this provision, an administrative monetary penalty under Article 83, depending on the circumstances of the specific case. The circumstances of this case, in particular the severity of the identified violations, which will be discussed in further parts of the justification, indicate that it would be appropriate and necessary to exercise this power.

In determining the specific sanctions for the violations identified in this case, the President of the UODO utilized the guidance contained in the EROD Guidelines 04/2022 on calculating administrative monetary penalties under the GDPR (version 2.1) adopted on May 24, 2023, hereinafter referred to as the "Guidelines 04/2022". The first step in the methodology adopted there for calculating administrative monetary penalties is "to determine the processing operations in the case and assess the application of Article 83(3) of the GDPR" (see paragraph 17 of the Guidelines 04/2022). Expanding on this guidance in paragraph 24 of its guidelines, EROD recommends first determining: a) whether the circumstances indicate a single behavior or multiple behaviors subject to penalty; b) in the case of a single behavior, whether this behavior constitutes a single violation or multiple violations; c) in the case of a single behavior that constitutes multiple violations, whether attributing one violation excludes attributing another violation, or whether they should be attributed concurrently.

The interpretation of the term "single behavior" is contained in paragraph 28 of the Guidelines 04/2022, referring to Article 83(3) of Regulation 2016/679, which speaks of "the same or related processing operations." According to it, "[t]he term 'related' refers to the principle that a single behavior may consist of several parts that are carried out as a result of a single act of will and are contextually (in particular regarding the identity of the data subject, the purpose, and the nature of the processing),

spatially, and temporally so closely related that from an objective point of view they can be considered a single coherent behavior."

Relating the above provisions of Regulation 2016/679 and the guidance contained in the Guidelines 04/2022 to the circumstances of this case, the President of the UODO found the following.

1. The President of the UODO found that the actions of the Medical Center considered in this case related to the implementation of ad hoc video monitoring in two rooms of the Department (...) in violation of applicable regulations (constituting a violation of Article 6(1) and Article 9(1) of Regulation 2016/679), as well as the failure to fulfill the information obligation towards the individuals whose personal data were subject to the registration in question (constituting a violation of Article 13(1) and (2) of Regulation 2016/679) constitute "a single coherent behavior" in the sense presented by EROD. Both of these actions of the Facility (also constituting a violation of Article 5(1)(a) and Article 5(2) of Regulation 2016/679) are, in the opinion of the President of the UODO, the result of a single act of will of the Administrator, who decided to implement a temporary, and in principle undisclosed to the individuals whose data are concerned, process of processing their personal data through video monitoring and the failure to fulfill the information obligation towards those individuals. The fact that the aforementioned processing operations constituting the subject of the identified violations of the provisions of Regulation 2016/679 (Article 6(1), Article 9(1), Article 13(1) and (2)) are related processing operations in the sense of Article 83(3) of Regulation 2016/679 is indicated – apart from being encompassed by a single act of will of the Medical Center – also by the common context of this processing. It combines these processing operations in the assessment of the President of the UODO:

- a) purpose of processing – it was to eliminate the causes and prevent in the future an increase in the number of symptoms of infections among newborns hospitalized in the wards (...);
- b) nature of processing – the monitoring applied in the wards (...) was intended to be covert (evidenced by: the devices used, namely clocks with image recording functions, and the failure to inform about the introduction of monitoring in the aforementioned area); the failure to meet the informational obligation towards the individuals whose data was processed in this manner was a natural and logical consequence of the covert nature of the processing assessed in this case;
- c) level of risk of processing – increased – in relation to other processes of personal data processing by the Medical Center concerning its patients, visitors, employees, etc. – the level of risk of the discussed processing process results from the fact that it was not covered by the technical and organizational security measures typically applied by the Medical Center to other data processing operations (in particular, monitoring, recording, and transferring personal data originating from covert monitoring took place outside the information systems and procedures designated – and thus properly secured – for such activities conducted on personal data originating from "overt" monitoring carried out in other rooms and parts of the Medical Center);
- d) identity of the individuals concerned – the processing processes covered by all violations related to the behavior of the Medical Center involving the use of covert monitoring (Article 6(1), Article 9(1), and Article 13(1) and (2) of Regulation 2016/679) concern the personal data of the same, precisely defined group of individuals – patients, their families, visitors, and staff of the Facility present in specific two wards (...);
- e) temporal context of processing – the duration of unlawful processing of personal data through covert monitoring, and thus the duration of all identified violations related to this processing, is the same and is strictly defined – it is the period from July 1 to July 23, 2023. Therefore, having established that: firstly, the actions of the Medical Center involving the implementation and allowing the operation of ad hoc and covert video monitoring and the failure to meet the informational obligation towards the individuals covered by this monitoring constitute one cohesive behavior (which results from their being encompassed by one act of will and the context of processing covered by this act of will), and secondly, this behavior violates several provisions of Regulation 2016/679 (Article 6(1), Article 9(1), Article 13(1) and (2), and consequently – Article 5(1)(a) and Article 5(2)), it should be further stated that none of these identified violations excludes – in the assessment of the President of the UODO – attributing another one to the Medical Center. In particular, the identification of a violation of the provisions defining the fundamental, general principles of processing (in this case – Article 5(1)(a) and

Article 5(2) of Regulation 2016/679) does not exclude attributing to the administrator (and imposing a financial sanction for this) a violation of specific provisions that specify these principles (Article 6(1), Article 9(1), Article 13(1) and (2) of Regulation 2016/679). The above allows for the attribution to the Medical Center of the aforementioned violations "in parallel" – none of them excludes the attribution of the remaining ones to the Medical Center. In such a situation, Article 83(3) of Regulation 2016/679 will apply to all the aforementioned violations.

2. The actions (omissions) of the Medical Center leading to the violation of the provisions of Article 24(1), Article 25(1), Article 32(1) and (2) – and consequently – Article 5(1)(f) and Article 5(2) of Regulation 2016/679 constitute "one cohesive behavior" in the sense presented by the EDPB in paragraph 28 of Guidelines 04/2022 and – at the same time – do not constitute such one behavior with the actions leading to the violation of Article 6(1), Article 9(1), Article 13(1) and (2) (and Article 5(1)(a) and Article 5(2)) of Regulation 2016/679 discussed above. The following circumstances testify to this:

a) Violations of the provisions of Article 24(1), Article 25(1), Article 32(1) and (2) and – consequently – Article 5(1)(f) and Article 5(2) of Regulation 2016/679 were not (unlike the behavior discussed above related to the implementation of covert monitoring) the result of a specific act of will, a single decision of the Medical Center. Their source was the unintentional omission to take actions implementing and enforcing the application of personal data protection measures stored on external data carriers (in particular, on memory cards used in video monitoring cameras). This omission occurred already at the stage of determining the methods of processing – as evidenced by the incorrect risk analysis related to the processing processes used in the Facility (which already constituted a violation of Article 25(1) of Regulation 2016/679) – and was continued during the processing itself (additionally leading to a state of violation of the provisions of Article 24(1) and Article 32(1) and (2) of Regulation 2016/679). It was a continuous process caused not so much by one act of will, but by the lack of one specific decision of the Medical Center that could have prevented the violations of all the provisions considered here – Article 24(1), Article 25(1), Article 32(1) and (2) and – consequently – Article 5(1)(f) and Article 5(2) of Regulation 2016/679.

b) As indicated above, the behavior of the Medical Center leading to the violation of the provisions of Article 24(1), Article 25(1), Article 32(1) and (2) and – consequently – Article 5(1).

1 lit. f) and Article 5(2) of Regulation 2016/679, this constitutes a continuous and long-term state. In contrast, its behavior related to the use of covert video surveillance (resulting in a violation of Article 6(1), Article 9(1), Article 13(1) and (2) and – consequently – Article 5(1)(a) and Article 5(2) of Regulation 2016/679) was an ad hoc, short-term action, intended to be one-time and temporally limited. Such a different temporal context of both behaviors (resulting in violations of both groups of provisions of Regulation 2016/679) does not allow for the conclusion that this is one coherent behavior of the Medical Center.

c) The purpose and nature of the processing, in connection with which the violations of the provisions of Article 24(1), Article 25(1), Article 32(1) and (2) and – consequently – Article 5(1)(f) and Article 5(2) of Regulation 2016/679 occurred, were the same in the case of all these violations. The above violations were identified in connection with the processing of personal data recorded in electronic form on portable data carriers, and this processing aimed at storing personal data on external carriers, possibly transferring them between other electronic devices (computers, cameras, servers, etc.). This defined purpose of processing distinguishes this behavior from the behavior related to the use of covert video surveillance, the aim of which was to use personal data obtained from visual recordings to enhance the level of medical care in the Facility.

d) The processing processes constituting the subject of both behaviors of the Medical Center (leading to violations of both groups of provisions of Regulation 2016/679) concerned personal data of various groups of individuals. As indicated above, the processing related to covert video surveillance violated the protection of personal data of a specific, defined, and relatively small number of individuals who were present in the two rooms covered by this surveillance. In contrast, the processing of personal data on unsecured portable data carriers could threaten the protection of personal data of all individuals whose data was in the possession of the Medical Center and who could be processed in this way (data of all patients, all employees, all individuals whose images were obtained through video

surveillance, including surveillance compliant with the provisions of Regulation 2016/679, etc.). Moreover, this threat concerned the data of all these individuals in the full scope of the data held by the Medical Center.

Having established that: firstly, the omissions of the Medical Center consisting of the failure to apply (both in the design phase and during processing) appropriate technical and organizational measures ensuring a level of security corresponding to the risk of processing data using external data carriers constitute one coherent behavior, and secondly, this behavior violates several provisions of Regulation 2016/679 (Article 24(1), Article 25(1), Article 32(1) and (2), and consequently Article 5(1)(f) and Article 5(2)), it should be further stated that none of these identified violations excludes – in the opinion of the President of the UODO – attributing another one to the Medical Center. In particular, the finding of a violation of the provisions defining the fundamental, general principles of processing (in this case – Article 5(1)(f) and Article 5(2) of Regulation 2016/679) does not exclude attributing to the administrator (and imposing a financial penalty for it) a violation of specific provisions that specify these principles (Article 24(1), Article 25(1), Article 32(1) and (2) of Regulation 2016/679, provided that an administrative fine is not imposed for violating Article 24(1), as it is not listed in Article 83(4)-(6) of Regulation 2016/679). The above allows for the attribution of the aforementioned violations to the Medical Center "in parallel" – none of them excludes the attribution of the remaining ones to the Medical Center. In such a situation, Article 83(3) of Regulation 2016/679 will apply to all the aforementioned violations.

3. Given that two separate behaviors of the Medical Center (not concerning the same or related processing operations) are subject to sanction in this case, Article 83(3) of Regulation 2016/679 will not apply to the concurrence of both groups of violations of the provisions of Regulation 2016/679. Consequently, the sum of both fines imposed for the violation of both groups of provisions of Regulation 2016/679 could exceed the amount of the fine (maximum threat) for one of them (the violations of both groups of provisions are equally serious since they include those that are subject to a "more serious" penalty – up to EUR 20,000,000 or up to 4% of total global annual turnover). It should be noted here that the only reason why the violations of Article 6(1), Article 9(1), Article 13(1) and (2) (and Article 5(1)(a) and Article 5(2) of Regulation 2016/679) are considered – alongside the violations of Article 24(1), Article 25(1), Article 32(1) and (2) (and Article 5(1)(f) and Article 5(2) of Regulation 2016/679) – in one proceeding (and assessed in one decision of the President of the UODO) is the circumstance of their identification during the proceedings regarding the notification of a data protection violation involving the loss or theft of memory cards from video surveillance devices. These violations do not concern the same or related processing operations within the meaning of Article 83(3) of the GDPR; they are considered within one decision because they coincidentally drew the attention of the President of the UODO at the same time, within the framework of an ongoing proceeding. There would be no obstacles to – given that separate behaviors of the Medical Center are considered – subject them to separate proceedings and individual decisions imposing sanctions for the identified violations. As stated in Guidelines 04/2022.

such a situation excludes the application of the limitation resulting from Article 83(3) of Regulation 2016/679 on the total amount of the imposed administrative fine to (maximum) the amount of the fine for the most serious violation (see paragraph 45 of the Guidelines 04/2022).

4. Summarizing the above:

a) The President of the UODO found that the Medical Center, through one act (described in point 1 above), violated several provisions of Regulation 2016/679 (Article 6(1), Article 9(1), Article 13(1) and (2), and consequently Article 5(1)(a) and Article 5(2) of Regulation 2016/679). For all these violations, the provision of Article 83(3) of Regulation 2016/679 was applied, and since all violations are threatened (in abstracto) with the same penalty resulting from Article 83(5) of Regulation 2016/679 (up to EUR 20,000,000 or up to 4% of annual turnover), all these violations must be attributed the same severity. The consequence of this is the inability to impose – for the aforementioned violations – a penalty higher than the maximum penalty for one of them (EUR 20,000,000 – due to the necessity of adopting the so-called "static maximum penalty" in relation to the Facility – see point 5 on page 40 of

the justification of this decision).

b) Through a separate act (described in point 2 above), the Medical Center violated further provisions of Regulation 2016/679 (Article 24(1), Article 25(1), and Article 32(1) and (2), and consequently Article 5(1)(f) and Article 5(2) of Regulation 2016/679). Due to this separateness of the Administrator's behavior, the President of the UODO did not consider them together with the previous violations and imposed a separate administrative fine for them. It should be noted that in the case of violations of the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, the penalty resulting from Article 83(4) of Regulation 2016/679 applies (up to EUR 10,000,000 or 2% of annual turnover). However, the violations of the aforementioned provisions subsequently result in violations of the principles of integrity and confidentiality, as well as accountability expressed in Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which violations are already threatened with the penalty specified in Article 83(5) of Regulation 2016/679 (up to EUR 20,000,000 or 4% of annual turnover). The consequence of this is the inability to impose – for all the aforementioned violations – a penalty higher than the maximum penalty for the most serious violation (that is, for the violation of Article 5(1)(f) and Article 5(2) threatened with a penalty of up to EUR 20,000,000 – due to the necessity of adopting the so-called "static maximum penalty" in relation to the Facility – see point 5 on page 49 of the justification of this decision).

B. Justification for the imposition and determination of the amount of the administrative fine for the violation of the provisions of Article 6(1), Article 9(1), and Article 13(1) and (2) of Regulation 2016/679, which resulted in the violation of Article 5(1)(a), and consequently also Article 5(2) of Regulation 2016/679. The administrative fine imposed on the Administrator was for the violation of Article 5(1)(a), Article 5(2), Article 6(1), Article 9(1), and Article 13(1) and (2) of Regulation 2016/679 – based on Article 83(5)(a) and (b) of this Regulation. At the same time, the administrative fine in the amount of PLN 687,534.75 (in words: six hundred eighty-seven thousand five hundred thirty-four zlotys and 75/100), imposed on the Administrator for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the fine for the most serious violation identified in this case, namely the violation of Article 5(1)(a) and Article 5(2) of Regulation 2016/679, which under Article 83(5)(a) of Regulation 2016/679 is subject to an administrative fine of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose an administrative fine, the President of the UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and influence the severity of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). In the opinion of the President of the UODO, this violation has significant weight and serious character, as the Administrator is a medical entity that provides medical services for a fee and is obliged to ensure patients a sense of security. From a trusted entity, such as the Medical Center, one should expect both knowledge of the regulations and their proper application, as well as higher standards of services provided. This Facility, by improperly processing the personal data of patients, guests, and employees through the installation of two additional monitoring devices in the rooms of Section (...) violated the principle of lawfulness of data processing referred to in Article 5(1)(a) of Regulation 2016/679, and consequently also the principle of accountability resulting from Article 5(2) of Regulation 2016/679. Furthermore, it should be emphasized that the Administrator did not fulfill the informational obligation towards individuals whose images were subject to image registration, as referred to in Article 13(1) and (2) of Regulation 2016/679. The above means that the Medical Center violated not only the basic obligations imposed by Regulation 2016/679 on administrators but also constituted a serious threat to the proper realization of rights.

Entitlements of Citizens Under the Constitution of the Republic of Poland.

In this case, there is a lack of evidence indicating that the individuals (patients, employees of the Facility) whose data was recorded by the video surveillance devices installed in 2 rooms of the Department (...) suffered property damage. Nevertheless, the mere improper processing of their personal data and the failure to inform them about it constitutes non-material damage (harm) for them, e.g., through the violation of their personal rights, such as mental well-being or the right to privacy, etc. It should also be emphasized that the actions of the Administrator constituted a gross violation of the intimacy and dignity of the patients due to the hidden nature of this monitoring.

According to the information provided by the Administrator in the ongoing correspondence, the temporary video surveillance in the Department (...) operated from July 1 to July 23, 2023 (this simultaneously constitutes a breach of the provisions of Regulation 2016/679) – thereby recording the images of 190 individuals, including 30 patients, 60 legal representatives of patients, 97 staff members, and 3 students undergoing internships (according to the information indicated in the supplementary form for reporting the breach of personal data protection).

****2. Intentional Nature of the Breach (Art. 83(2)(b) of Regulation 2016/679).** ** According to the Guidelines 04/2022 on calculating administrative fines based on the GDPR (adopted on May 24, 2023, version 2.1), “(...) ‘intent’ encompasses both knowledge and deliberate action, in connection with the characteristics of the prohibited act (...)” (p. 20, point 55). The ongoing explanatory proceedings and the explanations and evidence obtained during it confirm that the Administrator, by implementing temporary video surveillance, did not comply with its own applicable procedures related to the functioning of the existing surveillance conducted in the Facility, of which it had full knowledge and awareness. This position was also confirmed by the Administrator itself in a letter dated February 12, 2024, quoted as follows: “We are aware of the imperfections of the applied method of temporary monitoring.” It should also be recalled that the video surveillance installed in 2 rooms of the Department (...) was intended to be in the form of hidden monitoring, i.e., employees, patients, and visitors were not to be informed about the introduction of monitoring. Despite being aware of the applicable law and the implemented procedures regarding video surveillance in the facility, the Administrator deliberately did not include regulations concerning the installation of additional cameras in the aforementioned area – which further supports the assumption of intentionality in its actions. Therefore, it must be unequivocally recognized that the analyzed breach of the provisions of Regulation 2016/679 was a deliberate action by the Medical Center.

****3. Categories of Personal Data Affected by the Breach (Art. 83(2)(g) of Regulation 2016/679).** ** The personal data covered by the temporary video surveillance installed in 2 rooms of the Department (...) consisted of images of patients, visitors of patients, and staff of this medical facility. It should be noted that the specificity of the area where the recording devices were installed is associated with many intimate situations related to the postpartum period of patients and their newborn children. This means that the personal data processed within the framework of the monitoring also constitutes data subject to special protection under Article 9(1) of Regulation 2016/679 (i.e., health data). This imposes on the administrators of this data the obligation to treat this information with particular care, also due to the possible negative consequences for the individuals to whom this data pertains in the event of its disclosure to unauthorized persons, including discrimination or loss of good reputation. In this context, it is necessary to refer to Guidelines 04/2022, which state: “Regarding the requirement to consider the categories of personal data affected by the breach (Art. 83(2)(g) GDPR), the GDPR explicitly indicates the types of data that are subject to special protection, and thus a more rigorous response when imposing fines. This concerns at least the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual to whom the data pertains (...)” (p. 21, point 57).

****4. The Manner in Which the Supervisory Authority Became Aware of the Breach (Art. 83(2)(h) of Regulation 2016/679).** ** The supervisory authority became aware of the potential breach of personal data protection regulations on August 3, 2023, after the publication of an article on the website of the service (...) concerning the practices of the Medical Center related to the monitoring system used by this entity in 2 rooms of the Department (...), and not directly from the Administrator. Given that the

President of the UODO gained knowledge about the possibility of the Facility conducting activities contrary to applicable legal regulations, including the provisions of Regulation 2016/679 from media reports, in the opinion of the supervisory authority, this circumstance can be treated as having a detrimental impact on the amount of the imposed administrative fine.

In determining the amount of the administrative fine, the President of the UODO found no grounds to consider any mitigating circumstances that could influence the reduction of the final amount of the fine imposed on X. based in K. Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified breach in this case, were deemed neutral by the President of the UODO, meaning they had neither a detrimental nor a mitigating effect on the amount of the imposed administrative fine.

1. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). In the context of this premise, the purpose of the Administrator's action is significant, namely to minimize the damage suffered by the individuals whose data were subject to ad hoc video monitoring in 2 rooms of the Department (...). The President of the UODO did not record any such actions taken by the Administrator in this case. Given the presented factual state, this circumstance should be categorized as neutral.

2. Degree of responsibility of the administrator taking into account the technical and organizational measures implemented by them pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). This administrative fine was imposed on the Administrator for violating the provisions of Article 5(1)(a) of Regulation 2016/679 (principle of lawfulness, fairness, and transparency), Article 5(2) of Regulation 2016/679 (principle of accountability) in connection with Articles 6(1), 9(1), and 13(1) and (2) of Regulation 2016/679. The issue of the security principles of the processed personal data and the technical and organizational measures applied by the Administrator was not subject to analysis in this regard.

3. Any relevant previous violations by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any previous violations of data protection regulations on the part of the Medical Center, therefore there are no grounds to treat this circumstance as aggravating. It is the duty of every administrator to comply with the law, and thus the absence of previous violations cannot be considered a mitigating circumstance when imposing sanctions.

4. Degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The President of the UODO wishes to emphasize that at the time of initiating the explanatory proceedings (which were initiated by a letter from the supervisory authority dated August 7, 2023), the Administrator had already ceased conducting ad hoc video monitoring in 2 rooms of the Department (...), and thus the violation of the provisions of Regulation 2016/679. Consequently, the removal of the violation occurred without prior action by the authority, which means that there is no possibility to assess the degree of cooperation with the Administrator. The factual state presented in this manner cannot constitute an aggravating or mitigating circumstance when imposing sanctions.

5. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures against the Administrator in the examined case as mentioned in Article 58(2) of Regulation 2016/679, therefore the administrator had no obligation to take any actions related to their application, which actions, when assessed by the President of the UODO, could have a burdensome or mitigating effect on the assessment of the established violation.

6. Application of approved codes of conduct pursuant to Article 40 of Regulation 2016/679 or approved certification mechanisms pursuant to Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). X. based in K. does not apply approved certification mechanisms referred to in Article 42 of Regulation 2016/679. Furthermore, during the proceedings, the Facility did not inform the supervisory authority whether it applies approved codes of conduct referred to in Article 40 of Regulation 2016/679. It should be emphasized that the implementation and application of these are not, as stated in the

provisions of Regulation 2016/679, mandatory for administrators and processors, which means that the circumstance of their non-application cannot be interpreted against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

7. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits directly or indirectly obtained in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the administrator obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed decidedly negatively. On the other hand, the administrator's failure to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" – that is, those that occurred on the part of the entity committing the violation.

8. Other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, comprehensively considering the case, did not record any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine.

At the outset, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the EROD in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the violation of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). Among the provisions of Regulation 2016/679 violated by the Medical Center is Article 5(1)(a) of Regulation 2016/679, which defines the basic principles of processing. The violation of this provision falls – in accordance with Article 83(5)(a) of Regulation 2016/679 – into the category of violations subject to a higher penalty of the two dimensions provided for in Regulation 2016/679 (with a maximum amount of up to EUR 20,000,000 or up to 4% of the total annual turnover of the enterprise from the previous financial year). They are, therefore, more serious than other violations (indicated in Article 83(4) of Regulation 2016/679).

2. The President of the UODO assessed the violation identified in this case (in particular, the violation of the basic principles of processing) as a violation of high severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria from Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (constituting the "severity" of the violation) were taken into account, namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or negligent nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violation identified in this case leads to the conclusion that the level of its severity (understood in accordance with Guidelines 04/2022) is high. Consequently, this results in the acceptance – as the starting amount for calculating the penalty – of a value ranging from 20% to 100% of the maximum penalty that can be imposed on the Medical Center, that is – considering the limit specified in Article 83(5) of Regulation 2016/679 – from EUR 4,000,000 to EUR 20,000,000 (see Subsection 4.2.4 of Guidelines 04/2022). The President of the UODO deemed the starting amount of EUR 10,000,000.00 (equivalent to PLN 43,653,000) to be adequate and justified given the circumstances of this case.

3. The President of the UODO adjusted the starting amount corresponding to the high severity of the identified violation to the turnover of the Medical Center as a measure of its economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with

an annual turnover of EUR 10-50 million, the supervisory authority may consider making further calculations of the penalty based on a value ranging from 1.5% to 10% of the starting amount. Given that the turnover of the Medical Center in 2023 amounted to (...) PLN, which is (...) EUR (according to the average exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount of the penalty subject to calculations to a value corresponding to 3% of the starting amount, that is, EUR 300,000.00 (equivalent to PLN 1,309,590.00).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before, during, and after the occurrence of the violation. A detailed assessment and justification of the impact of each of these criteria on the assessment of the violation have been presented above. The President of the UODO, considering the high severity of the violation, recognized that an aggravating circumstance in this case is the manner in which the authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). In conducting the analysis in this case, the supervisory authority did not take into account any mitigating circumstances that would affect the reduction of the penalty. The remaining criteria (from Article 83(2)(c), (d), (e), (f), (i), (k)) of Regulation 2016/679 – as indicated above – did not have either a mitigating or aggravating effect on the assessment of the violation and consequently on the amount of the penalty. Due to the existence of an aggravating circumstance in the case, it is therefore reasonable to make a correction to the amount of the penalty determined taking into account the turnover of the Medical Center (point 3 above); in the opinion of the President of the UODO, an appropriate increase of 5% – to the amount of EUR 315,000.00 (equivalent to PLN 1,375,069.50) is justified given the impact of these criteria on the assessment of the violation.

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). As indicated above, the most serious violation in this case is the violation of Article 5(1)(a), which is subject to an administrative monetary penalty of up to EUR 20,000,000, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this perpetrator expressed as a percentage (4%) of its turnover would amount to (...) EUR, therefore, it is necessary to apply in this case – as the higher amount – the "static maximum amount." amounting to 20,000,000 EUR for the violation in question. The amount of 315,000.00 EUR indicated above obviously does not exceed the amount of 20,000,000 EUR.

6. Despite the fact that the penalty amount established according to the above principles does not exceed the legally defined maximum penalty, the President of the UODO deemed that it requires further adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for determining penalties (see Chapter 7 of Guidelines 04/2022). Undoubtedly, the monetary penalty equivalent to 315,000.00 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal of punishing unlawful behavior) and deterrent (allowing effectively to dissuade both the Medical Center and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be, in the opinion of the President of the UODO, a disproportionate penalty due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU)

2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected sectoral provisions. Commentary). Therefore, taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the penalty to 50% of the amount obtained after considering the aggravating circumstances (see point 4 above), that is, to the amount of 157,500.00 EUR (equivalent to 687,534.75 PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount, indeed, constitutes a threshold above which any further increase in the penalty amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the penalty amount could come at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

C. Justification for the imposition and determination of the amount of the administrative monetary penalty for the violation of the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, which resulted in the violation of Article 5(1)(f), and consequently Article 5(2) of Regulation 2016/679.

The administrative monetary penalty against the Administrator was imposed for the violation of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 – based on Article 83(5)(a) of that regulation.

At the same time, the administrative monetary penalty in the amount of 458,356.50 PLN (in words: four hundred fifty-eight thousand three hundred fifty-six zlotys and 50/100), imposed on the Administrator jointly for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the penalty for the most serious violation established in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which under Article 83(5)(a) of Regulation 2016/679 is subject to an administrative monetary penalty of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose the administrative monetary penalty, the President of the UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have an aggravating effect on the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The violation of data protection regulations established in this case, which resulted in (and still results in) the possibility of unauthorized access to data located on unsecured external data storage devices (i.e., memory cards) by unauthorized person(s) (violation of the confidentiality principle), is of significant weight and serious nature, as it creates a high risk of negative consequences for the individuals whose data are concerned. The Medical Center's violation of the obligation to apply security measures to protect processed data from being disclosed to unauthorized persons entails not only a potential but also a real possibility of these data being used by third parties without the knowledge and against the will of the individual whose data are concerned, in violation of the provisions of Regulation 2016/679. Furthermore, up until the issuance of this decision, the lost or stolen external data storage devices have not been recovered, so unauthorized person(s) may still have access to personal data located on that storage device. The violation of the provisions and principles concerning the protection of personal data in connection with their processing by the Facility in the course of its business activities in the field of medical services without implementing adequate technical and organizational measures (violation of Article 32).

****1. Introduction****

Paragraph 1 and paragraph 2 of Regulation 2016/679 are of significant importance also due to the considerable scale of data processing by the Institution and the nature of the activities it performs, and thus also the scope of the data processed (data of special categories, including, among others, health data). It should be emphasized once again that the Medical Center provides medical services in Poland, including in the area of (...). This fact determines the scope of the data processed by it, the disclosure of which may cause particular harm to the individuals concerned. It should also be noted that the data processed by the Administrator constitutes medical secrecy, which also affects the necessity of accepting the significant nature and weight of the violation.

****2. Violations of Regulation 2016/679****

Furthermore, the violations of the provisions of Regulation 2016/679 identified during the course of the explanatory proceedings and subsequently as a result of the administrative proceedings were associated with a breach of the principle of integrity and confidentiality (Article 5(1)(f) of Regulation 2016/679), i.e., the obligation to process personal data of employees, patients, and visitors in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures, as well as the principle of accountability (Article 5(2) of Regulation 2016/679), which made them significant and serious due to the fact that all the aforementioned organizational and technical measures are fundamental for ensuring the security of data processing from a technical and organizational perspective.

****3. Lack of Evidence of Material Damage****

In this case, there is a lack of evidence indicating that the individuals (patients, their visitors, and employees of the Company) whose data was accessed by third parties suffered material damage; nevertheless, the mere breach of the confidentiality of their data constitutes non-material damage (harm) for them, e.g., through the violation of their personal rights, such as mental well-being, the right to privacy, etc. Individuals whose data was unlawfully obtained as a result of a breach of personal data protection may at least feel apprehensive about losing control over their personal data, identity theft, or identity fraud, discrimination (health data), or finally – financial loss. As indicated by the District Court in Warsaw in the judgment of August 6, 2020, case file XXV C 2596/19, apprehension, and thus the loss of security constitutes a real non-material damage associated with the obligation to remedy it. Moreover, the Court of Justice of the EU in its ruling of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the apprehension of potential misuse of personal data by third parties, which a person whose data is concerned experiences following a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

****4. Improper Risk Analysis by the Administrator****

It should also be emphasized that the Administrator conducted a risk analysis improperly, as demonstrated above, as a result of which it did not apply appropriate security measures to ensure the protection of personal data processed using external data carriers (i.e., memory cards). The duration of the violation of the provisions of Regulation 2016/679 covered the period of the operation of temporary video monitoring in 2 rooms of the Department (...), i.e., from July 1 to July 23, 2023.

****5. Consideration of Personal Data Affected****

The authority, when analyzing this matter, took into account the fact that the personal data on the lost data carrier concerned 190 individuals, including 30 patients, 60 legal representatives of patients, 97 personnel members, and 3 students undergoing internships (according to the Administrator's declaration in the supplementary form for reporting the breach of personal data protection); however, it should be emphasized that according to the adopted guidelines aimed at harmonizing the methodology used by supervisory authorities in calculating the amount of the financial penalty, it is obliged to assess the premise referred to in Article 83(2)(a) of Regulation 2016/679 comprehensively, i.e., to take into account in its assessment the weight, nature, and duration of the violation of the

provisions of Regulation 2016/679, the nature, scope, or purpose of the specific processing, the number of affected individuals whose data is concerned, and the extent of the damage incurred by them. As indicated in Guidelines 04/2022 (section 4.2.1, point iv), when analyzing all elements constituting the violation, the number of individuals whose data is concerned and who are specifically affected by the violation, as well as, importantly, those who may potentially be affected, should also be considered.

****6. Systemic Nature of the Violation****

Considering this circumstance, the Authority may conclude that the cited (...) "violation is of a 'systemic' nature and therefore may affect, even at different times, additional individuals whose data is concerned, who have not lodged complaints or notifications with the supervisory authority." The supervisory authority may, depending on the circumstances of the case, take into account the ratio of the number of affected individuals whose data is concerned to the total number of individuals whose data is concerned in a given context (e.g., the number of citizens, clients, or employees) to assess whether the violation is of a systemic nature. Taking into account the above EROD guidelines, the Administrator's failure to ensure an appropriate level of security for the processed personal data, as an accepted action in the organization despite only one identified case of a breach of personal data protection, could potentially concern all patients and employees, and thus have a systemic nature (the aforementioned individuals could potentially be exposed to the loss of confidentiality of their data processed on external data carriers).

data carriers). Therefore, the supervisory authority rightly assessed this circumstance as aggravating.

2. The unintentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). The loss of control over personal data of individuals whose data is on lost or stolen external data carriers (i.e., memory cards) became possible due to the Medical Center's failure to fulfill its obligation to implement appropriate security measures to ensure the protection of this data. In the opinion of the supervisory authority, this indicates the unintentional nature of the violation, resulting from the Administrator's negligence, who did not properly conduct a risk analysis in the area covered by the personal data protection violation. In this case, the Facility should have considered that the adopted solutions would not ensure an adequate level of security for personal data, which could lead to a violation of personal data protection regulations. Considering the findings in the case subject to the resolution of this decision, it should be stated that the Facility did not act intentionally; however, it committed negligence resulting in a significant increase in the risk of violating the availability and confidentiality of the processed data, which indicates gross negligence and constitutes a significant circumstance affecting the severity of the administrative monetary penalty.

3. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). The personal data on the lost or stolen unencrypted memory cards included, among others, images of patients, visitors of patients, and staff of the Department (...) recorded by monitoring devices in the patient rooms. Furthermore, it should be noted that the specificity of the area where the recording devices were installed (image recording during the provision of health services) was associated with many intimate situations related to the postpartum period of patients and their newborn children. This means that the personal data on the aforementioned memory cards also constituted data subject to special protection under Article 9(1) of Regulation 2016/679, as they relate to health status. This imposes on the administrators of this data an obligation to treat this information with particular care, also due to the possible negative consequences for the individuals to whom this data pertains, in the event of its disclosure to unauthorized persons, including discrimination or loss of good reputation.

In this context, it is worth recalling Guidelines 04/2022, which state: "Regarding the requirement to take into account the categories of personal data affected by the violation (Article 83(2)(g) of the GDPR), the GDPR clearly indicates the types of data that are subject to special protection, and thus a more rigorous response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual to whom the data pertains (...)" (p. 21, para. 57).

In determining the amount of the administrative monetary penalty, the President of the UODO found no grounds to consider any mitigating circumstances that could affect the reduction of the final penalty imposed on X. based in K. Other circumstances, indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation in this case, were considered by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the harm suffered by the individuals whose data was affected (Article 83(2)(c) of Regulation 2016/679). The Administrator, in accordance with the declaration indicated in section 10 of the supplementary notification of the violation, informed that on September 15, 2023, he completed the process of notifying the individuals whose data was subject to the violation (i.e., identified individuals present in the rooms covered by the recording on memory cards), thus properly fulfilling the obligation imposed on the administrator in Article 34(1) of Regulation 2016/679. It should be emphasized that the mere fulfillment by the Medical Center of the aforementioned obligation to inform data subjects about the occurrence of a personal data breach cannot be interpreted as a mitigating factor and having a reducing effect on the amount of the imposed administrative monetary penalty.

2. The degree of responsibility of the administrator, taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The President of the UODO found in this case a violation by the Medical Center of the provisions of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the violation of personal data protection. It is evident that in the context of the nature, purpose, and scope of the processing of personal data, the Administrator did not "do everything that could have been expected of him"; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the violation itself; it is not merely a factor influencing – either mitigating or aggravating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be recognized by the President of the UODO in this case as a circumstance that could additionally...
impact on the stricter assessment of the violation and the imposition of an administrative monetary penalty on the Administrator.

3. Any relevant prior violations by the administrator (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any previous violations of data protection regulations on the part of the Medical Center, which means there are no grounds to consider this circumstance as aggravating. It is the duty of every administrator to comply with legal provisions, and therefore the absence of prior violations cannot also be considered a mitigating circumstance when imposing sanctions.

4. The degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The President of the UODO does not have information indicating that the Administrator took any actions aimed at mitigating the negative effects after reporting the data protection violation and initiating administrative proceedings. The Administrator only properly notified the individuals whose personal data were subject to the temporary monitoring in 2 rooms of the Department (...). In the absence of other evidence indicating the execution of the aforementioned actions, the supervisory authority cannot accept the analyzed premise as mitigating.

5. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of the UODO identified the violation by the Administrator of data protection regulations as a result of a preliminary report of the data protection violation submitted by the Medical Center on July 26, 2023, which was subsequently supplemented on September 15, 2023. By making the report, the Administrator fulfilled a legal obligation, thus there are no grounds to consider this fact as a mitigating circumstance. As indicated by the EROD in Guidelines 04/2022 (p.

32), “According to Article 83(2)(h) of the GDPR, the manner in which the supervisory authority became aware of the violation may constitute a significant aggravating or mitigating circumstance. In assessing this aspect, particular importance may be assigned to the issue of whether the administrator or processor notified the supervisory authority of the violation on their own initiative, and if so, to what extent, before the supervisory authority was informed of the violation through – for example – a complaint or proceedings. This circumstance is irrelevant when the administrator is subject to specific obligations regarding the reporting of violations (e.g., the obligation to report a personal data breach specified in Article 33 of the GDPR). In such cases, the fact of making a report should be considered a neutral circumstance” (p. 31, point 98).

6. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any measures against the Administrator in the case under consideration as mentioned in Article 58(2) of Regulation 2016/679, which means that the administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of the UODO, could have had an aggravating or mitigating impact on the assessment of the identified violation.

7. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). X. based in K. does not apply approved certification mechanisms referred to in Article 42 of Regulation 2016/679. Furthermore, during the proceedings, the Facility did not inform the supervisory authority about the application of approved codes of conduct referred to in Article 40 of Regulation 2016/679. It should be emphasized that the implementation and application of these are not, as stipulated by the provisions of Regulation 2016/679, mandatory for administrators and processors, which means that the circumstance of their non-application cannot be considered detrimental to the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as means guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

8. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the administrator obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the absence of such benefits for the administrator, as a natural state independent of the violation and its effects, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits “obtained” – arising on the part of the entity committing the violation.

9. Other aggravating or mitigating factors applicable to the circumstances of the case (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, comprehensively considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed penalty.

administrative monetary penalty.

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the EROD in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the identified violation of the provisions of Regulation 2016/679 in this case (see Chapter 4.1 of Guidelines 04/2022). Among the provisions of Regulation 2016/679 violated by the Medical Center are the provisions of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which define the basic principles of processing. The violation of these provisions falls—according to Article 83(5)(a) of Regulation 2016/679—into the category of violations subject to a

higher penalty among the two dimensions of penalties provided for in Regulation 2016/679 (with a maximum amount of up to EUR 20,000,000 or up to 4% of the total annual turnover of the enterprise from the previous financial year). They are, therefore, in abstracto more serious than other violations (indicated in Article 83(4) of Regulation 2016/679).

2. The President of the UODO assessed the identified violation in this case (in particular, the violation of the basic principles of processing) as a violation of high severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors listed in Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (constituting the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted here that considering their cumulative impact on the assessment of the identified violation in this case treated as a whole leads to the conclusion that the level of its seriousness (understood in accordance with Guidelines 04/2022) is high. Consequently, it was accepted—as the starting amount for calculating the penalty—a value falling within the range of 20% to 100% of the maximum penalty amount that could be imposed on the Medical Center, that is—considering the limit specified in Article 83(5) of Regulation 2016/679—from the amount of EUR 4,000,000 to the amount of EUR 20,000,000 (see Subchapter 4.2.4 of Guidelines 04/2022). The President of the UODO considered the starting amount of EUR 10,000,000.00 (equivalent to PLN 43,653,000) to be adequate and justified by the circumstances of this case.

3. The President of the UODO adjusted the starting amount corresponding to the high severity of the identified violation to the turnover of the Medical Center, as a measure of its economic power (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises with an annual turnover of EUR 10-50 million, the supervisory authority may consider making further calculations of the penalty amount based on a value falling within the range of 1.5% to 10% of the starting amount. Given that the turnover of the Medical Center in 2023 amounted to (...) PLN, which is (...) EUR (according to the average exchange rate on January 29, 2024), the President of the UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 3% of the starting amount, that is, the amount of EUR 300,000.00 (equivalent to PLN 1,309,590.00).

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate—as assumed by Guidelines 04/2022—to the subjective side of the violation, that is, to the entity itself that is the perpetrator of the violation and to its behavior before, during, and after the occurrence of the violation. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The supervisory authority did not take into account any circumstances, either aggravating or mitigating, that would affect the amount of the administrative monetary penalty. The remaining factors (from Article 83(2)(c), (d), (e), (f), (h), (i), (j), (k) of Regulation 2016/679)—as indicated above—did not have either a mitigating or aggravating effect on the assessment of the violation and consequently on the penalty amount. Due to the absence of any aggravating or mitigating circumstances in the case, the President of the UODO did not make any adjustments to the established penalty, leaving it at the level of EUR 300,000.00 (equivalent to PLN 1,309,590.00).

5. The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above does not exceed—according to Article 83(3) of Regulation 2016/679—the legally defined maximum penalty amount provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). As indicated above, the most serious violation in this case is the violation of Article 5(1)(f) and Article 5(2), subject to an administrative monetary penalty of up to EUR 20,000,000, and in the case of an enterprise—up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this perpetrator of the violation expressed as

a percentage (4%) of its turnover would amount to (...) EUR, therefore, the "static maximum amount" of EUR 20,000,000 should be applied in this case as the higher amount for the examined violation. The indicated amount of EUR 300,000.00 obviously does not exceed the amount of EUR 20,000,000.

6. Despite the fact that the amount determined in accordance with the above the penalty amount does not exceed the legally defined maximum penalty. The President of the UODO (Personal Data Protection Office) determined that it requires further adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty assessment (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary penalty equivalent to 300,000.00 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal of punishing unlawful behavior) and deterrent (effectively discouraging both the Medical Center and other administrators from committing future violations of the provisions of Regulation 2016/679). However, such a penalty would be, in the opinion of the President of the UODO, a disproportionate penalty due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case" (P. Litwiński (ed.), Regulation of the European Parliament and Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in] P. Litwiński (ed.) General Data Protection Regulation. Personal Data Protection Act. Selected sectoral provisions. Commentary). Therefore, considering the proportionality of the penalty, the President of the UODO further reduced the penalty amount – to 35% of the amount obtained after taking into account the aggravating circumstances (see point 4 above), that is, to the amount of 105,000.00 EUR (equivalent to 458,356.50 PLN). In his opinion, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which any further increase in the penalty amount will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the penalty amount could occur at the expense of its effectiveness and deterrent nature, as well as consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

In the opinion of the President of the UODO, the administrative monetary penalties imposed in the total amount of 1,145,891.25 PLN (in words: one million one hundred forty-five thousand eight hundred ninety-one zlotys and 25/100) for the violations of the provisions of Regulation 2016/679 identified in this decision fulfill, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., they will be effective, proportional, and deterrent in this individual case. According to the President of the UODO, the administrative monetary penalties imposed on the Medical Center will be effective, as they will lead to a situation in which the Facility will comply with the applicable legal provisions and will permanently cease violating the provisions on personal data protection by using video surveillance in the facility (i.e., in patient rooms) without legal basis. The effectiveness of the administrative monetary penalties is therefore equivalent to the guarantee that the Administrator, from the moment of the conclusion of this proceeding, will approach the requirements set by the personal data protection regulations with the utmost diligence.

The administrative monetary penalties imposed are also proportional to the identified violation of the provisions of Regulation 2016/679, especially regarding its severity, impact, the number of affected individuals, and the high risk of negative consequences that these individuals face in connection with this violation. The amount of the penalties has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, does not create a situation in which the necessity of payment would lead to negative consequences in the form of a significant deterioration of the Administrator's financial situation. In the opinion of the President of the UODO, the Medical Center should and is able to bear the consequences of its negligence in the area of data protection, thus the imposition of administrative monetary penalties is fully justified.

In the opinion of the President of the UODO, the administrative monetary penalties imposed meet, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679 due to the seriousness of the identified violation of the provisions of Regulation 2016/679 in the context of the fundamental purpose of Regulation 2016/679 – the protection of the fundamental rights and freedoms of individuals, in particular the right to personal data protection.

Referring to the amount of the administrative monetary penalties imposed on the Administrator, the President of the UODO concluded that they are proportional to the financial situation of the Administrator and will not constitute an excessive burden for him. The financial report submitted by the Administrator on April 2, 2024, indicates that the net sales revenue as of the end of the 2023 financial year amounted to (...) PLN, which means that the administrative monetary penalties in this case, imposed in total, constitute approximately (...) % of the aforementioned amount. At the same time, it is worth emphasizing that the total amount of imposed penalties is only 1.31% of the maximum penalty amount that the President of the UODO could – in accordance with Article 83(5) of Regulation 2016/679 – impose on the Administrator for the identified violation of the provisions of Regulation 2016/679 in this case (i.e., 20,000,000 euros).

In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalties will serve a repressive function in these specific circumstances, as they will constitute a response to the violation by the Medical Center of the provisions of Regulation 2016/679. and preventive, as they will contribute to preventing future violations by the Administrator of obligations arising from the provisions on the protection of personal data.

In the opinion of the President of the UODO, the administrative monetary penalties applied meet, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679, due to the seriousness of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of lawfulness, fairness, and transparency expressed in Article 5(1)(a) of Regulation 2016/679, as well as the principle of confidentiality and integrity referred to in Article 5(1)(f) of Regulation 2016/679.

Pursuant to the provisions of Article 103 of the Act of May 10, 2018 on the protection of personal data (Journal of Laws of 2019, item 1781), the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of the Office for Personal Data Protection, based on Article 83(4)(a) and Article 83(5)(a) in connection with Article 83(3) of Regulation 2016/679 and in connection with Article 103 of the Act of May 10, 2018 on the protection of personal data, for the violation of:

- Article 6(1), Article 9(1), Article 13(1) and (2) of Regulation 2016/679, which resulted in a violation of Article 5(1)(a), and consequently also Article 5(2) of Regulation 2016/679, imposed on the Medical Center – applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 687,534.75 PLN (which is equivalent to 157,500.00 EUR),
- Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, which resulted in a violation of Article 5(1)(f), and consequently also Article 5(2) of Regulation 2016/679, imposed on the Medical Center – applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 458,356.50 PLN (which is equivalent to 105,000.00 EUR), i.e. in the total amount of 1,145,891.25 PLN (which is equivalent to 262,500.00 EUR).

The purpose of the imposed administrative monetary penalties is to ensure compliance by X. based in K. with the provisions of Regulation 2016/679 in the future, and consequently to conduct data processing processes in accordance with applicable legal provisions.

In this factual and legal state, the President of the Office for Personal Data Protection decided as

stated in the operative part.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2025-01-17

Information entered by:

Wioletta Golańska

2025-01-27 13:47:03

Last modified by:

Grzegorz Cześnik

2025-03-04 08:33:47